



2025/2026

Alternance de 2ème année

Filière : Réseaux et Télécommunications (parcours cybersécurité)

Sécurisation d'une infrastructure client santé

Présenté par : Jules TEYSSIER

Version publique : les résultats chiffrés de l'audit PingCastle, l'organigramme de l'agence et les noms des personnes ont été retirés. Le laboratoire ne contient aucune donnée de client réel.

Responsable entreprise : (nom retiré)
Responsable IUT : (nom retiré)

Remerciements

Je tiens à remercier le directeur technique de XEFI Advanced, pour m'avoir accueilli au sein de l'entreprise et pour son accompagnement tout au long de cette alternance. Sa confiance, notamment en me confiant des missions techniques en autonomie, a été essentielle à l'acquisition de nombreuses compétences dans des domaines variés de l'informatique.

Je souhaite également remercier mon collègue référent pour son accompagnement durant cette alternance, ainsi que pour sa présence lors de ma soutenance.

Je remercie l'ensemble des membres de l'équipe XEFI Advanced Auvergne pour leur accueil et la bonne ambiance de travail au quotidien.

Je remercie mon tuteur IUT pour son suivi et ses conseils relatifs à la rédaction de ce rapport et à la préparation de la soutenance.

Je souhaite également remercier l'ensemble des professeurs du département Réseaux et Télécommunications de l'IUT Clermont-Ferrand, grâce à qui j'ai pu suivre ce cursus au cours de ces trois années.

Je remercie enfin toutes les personnes qui prendront le temps de lire ce rapport.

Table des matières

Introduction 6
1. Présentation et contextualisation 7
a. Xefi Advanced Auvergne 7
i. Histoire et organisation 7
ii. Secteurs d'activités et partenaires 9
b. Ma mission 10
i. Constat 10
ii. Objectifs et périmètre de la mission 11
iii. Architecture et environnement de simulation 12
iv. Outils utilisés 14
2. Réalisation technique 18
a. Mise en place du laboratoire et introduction des vulnérabilités 19
i. Choix et rôle de l'environnement de virtualisation 19
ii. Déploiement du contrôleur de domaine 20
iii. Introduction volontaire des vulnérabilités 21
b. Audit initial de l'infrastructure 22
i. Présentation de l'outil PingCastle 22
ii. Le modèle de score 23
iii. Résultats de l'audit initial 23
c. Durcissement de l'infrastructure 25
i. Désactivation des protocoles obsolètes 25
ii. Renforcement de la politique de mots de passe 26
iii. Correction de la gestion des comptes et des privilèges 28
iv. Vérification des correctifs 29
d. Audit final et comparaison 29
i. Comparaison des scores 29
ii. Ce qui n'a pas été corrigé, et pourquoi 30
e. Mise en place de la supervision 31
i. Le principe de la supervision 31
ii. Installation du serveur de supervision 32
iii. Préparation du contrôleur de domaine 34
iv. Configuration des éléments supervisés 36
v. Démonstration de la détection d'incident 37
3. Bilan 38

a. Résultats obtenus 38
b. Difficultés rencontrées 38
c. Perspectives 39
Conclusion 40
Bilan humain 41
Abstract 42
Glossaire 43
Bibliographie 45
Annexes 46

Table des figures

Figure 1 : Logo de la société XEFI 7
Figure 2 : Logo historique d'IBO 7
Figure 3 : Localisation de XEFI Ingénierie en France 8
Figure 4 : Localisation de l'agence à Clermont-Ferrand 8
Figure 5 : Zone de chalandise (région Auvergne-Rhône-Alpes) 9
Figure 6 : Organigramme de l'agence 9
Figure 7 : Architecture de l'environnement de simulation : contrôleur de domaine, postes clients, pare-feu Sophos et supervision Centreon au sein d'un réseau isolé. 13
Figure 8 : Modèle d'architecture réseau sécurisée : segmentation en zones : pare-feu de périmètre Sophos, routeur/DMZ, switch cœur, zone LAN interne et zone DMZ publique. 14
Figure 9 : Logo pingcastle 15
Figure 10 : Schéma du fonctionnement de ping castle 16
Figure 11 : Logo Centreon 16
Figure 12 : Processus de collecte de métriques par Centreon sur la VM supervisée 17
Figure 13 : Logo HP ProLiant DL360 Gen9 17
Figure 14 : Logo Proxmox VE 17
Figure 15 : Logo Windows Server 2019 18
Figure 16 : Logo Debian 18
Figure 17 : Logo Sophos XG 18
Figure 18 : Logo Wireshark 18
Figure 19 : Architecture technique du Lab sur un hyperviseur 20
Figure 20 : Validation de la promotion de la VM en contrôleur de domaine 21
Figure 21 : Tableau des vulnérabilités 22
Figure 22 : Export du résultat ping Caste avant durcissement 24
Figure 23 : Tableau récapulatif du résultat ping Castle avant durcissement 24
Figure 24 : SMBv1 désactivé + signature SMB activée + LLMNR désactivé via GPO 26
Figure 25 : Schéma de politique de mot de passe recommandé par l'ANSSI 27
Figure 26 : Commande powershell pour retrouver les comptes inactifs 28
Figure 27 : Désactivation d'un compte admin inactif 29
Figure 28 : Schéma des requêtes Centreon 32
Figure 29 : État des services Centreon 33
Figure 30 : Page d'accueil web Centreon après installation 34
Figure 31 : Installation de SNMP sur le Windows Server 34
Figure 32 : Configuration du service SNMP 35
Figure 33 : Test de réponse SNMP depuis Centreon 35
Figure 34 : Fonctionnement de Centreon pour interroger une machine 36
Figure 35 : Template grisé sur la version de Centreon utilisée 36
Figure 36 : Ajout de la commande de vérification du CPU 36
Figure 37 : Visualisation des trois indicateurs dans Centreon 37

Introduction

En deuxième année de BUT Réseaux et Télécommunications, parcours Cybersécurité, j'effectue mon alternance en tant que Technicien Conseil chez XEFI Clermont-Ferrand. Ce poste m'a confronté à la gestion d'infrastructures pour des clients aux environnements variés, dont certains évoluent dans des secteurs critiques comme la santé.

Ces structures manipulent des données sensibles au sens du RGPD et dépendent d'une disponibilité totale de leurs systèmes pour assurer la continuité des soins. Face à la recrudescence des cyberattaques ciblant ce secteur, les infrastructures reposant sur Active Directory montrent des lacunes face aux menaces actuelles.

Pour répondre à ce problème sans toucher à la production des clients, j'ai conçu un lab de maquettage isolé simulant un environnement client type, afin de l'auditer, de le durcir et de l'instrumenter contre les risques d'intrusion et de ransomware.

De ce constat découle la problématique suivante : **Comment durcir et moderniser l'infrastructure Active Directory d'un client du secteur de la santé afin d'adapter sa posture de sécurité aux menaces actuelles, sans impacter sa production critique ?**

Après avoir présenté le contexte de mon alternance et la structure de XEFI, je détaillerai les différentes étapes techniques du processus, de l'audit initial à la mise en place des correctifs. Un bilan abordera ensuite la supervision active sous Centreon, les difficultés rencontrées et les enseignements tirés.

1. Présentation et contextualisation

a. Xefi Advanced Auvergne

i. Histoire et organisation



Figure 1 : Logo de la société XEFI

Le groupe XEFI

Fondé en 1997 à Lyon par Sacha Rosenthal, XEFI est un prestataire informatique national qui accompagne TPE, PME et collectivités à travers plus de 150 agences en France et en Europe. Le groupe couvre la maintenance, le matériel, l'impression et la sécurité réseau, et exploite ses propres datacenters certifiés ISO 27001 et HDS pour ses offres Cloud et d'hébergement.

XEFI Advanced Auvergne (ex-IBO)



Figure 2 : Logo historique d'IBO

Anciennement IBO (fondée en 1990, intégrée au groupe en 2022), XEFI Advanced Auvergne est le pôle technique avancé de l'organisation locale. Elle est spécialisée dans les infrastructures complexes (serveurs, réseaux, Firewalls, Active Directory), les services managés et le Cloud (administration de SI critiques, infogérance de niveau 2 et 3) et l'hébergement de ressources virtualisées sécurisées.

Localisation :

Implantée à Clermont-Ferrand, l'agence occupe une position centrale en France, au cœur de la région Auvergne-Rhône-Alpes.

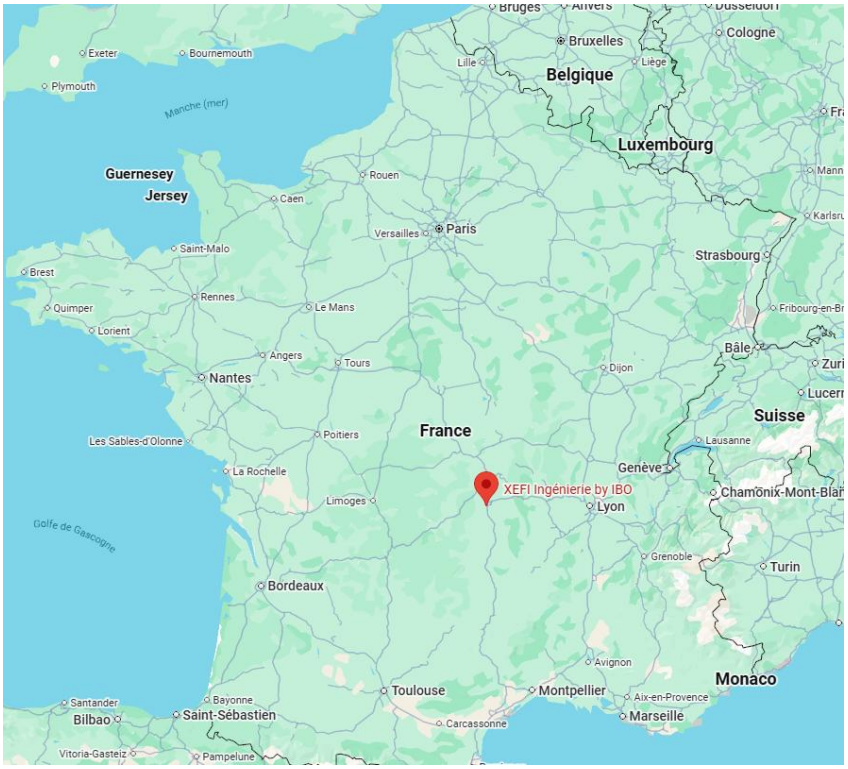


Figure 3 : Localisation de XEFI Ingénierie en France

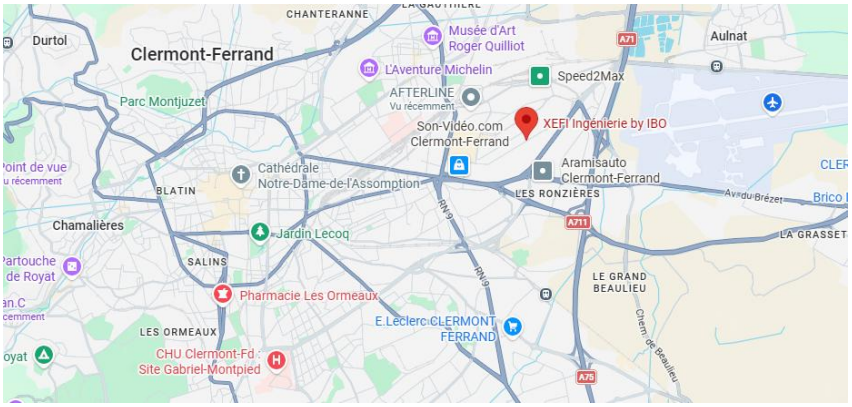


Figure 4 : Localisation de l'agence à Clermont-Ferrand

Zone de chalandise :

L'agence rayonne principalement sur la région Auvergne-Rhône-Alpes, où se concentre l'essentiel de sa clientèle.

Elle accompagne ainsi les TPE, PME et collectivités locales réparties sur ce territoire.

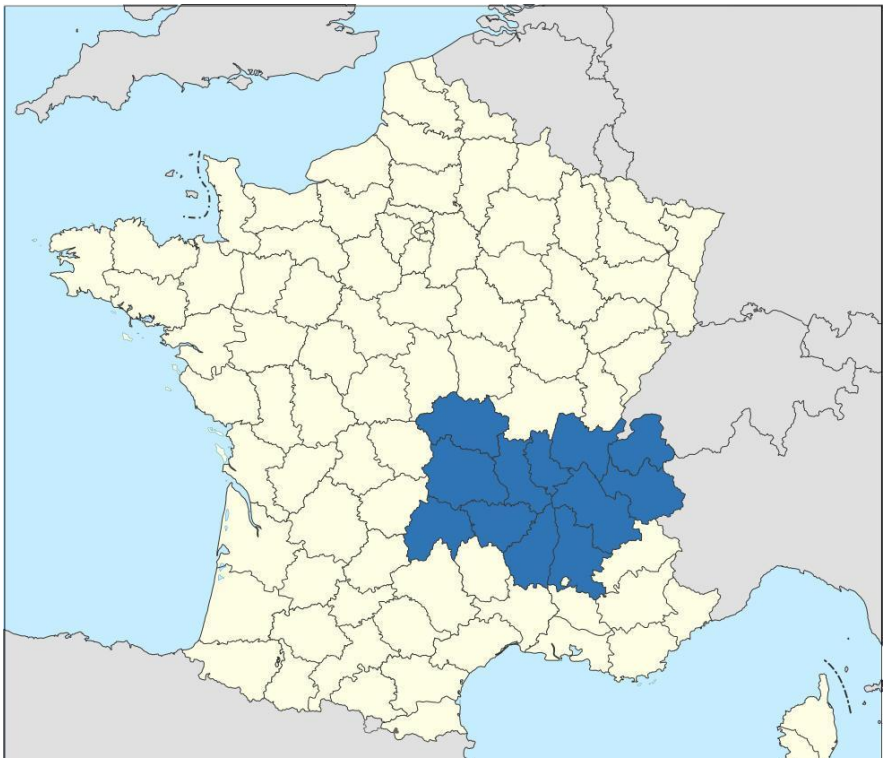


Figure 5 : Zone de chalandise (région Auvergne-Rhône-Alpes)

Organigramme :

Image retirée de la version publique

Organigramme : noms et numéros internes de l'agence

Figure 6 : Organigramme de l'agence

ii. Secteurs d'activités et partenaires

Activité, produits & services

Au fil des années et de son intégration au sein d'un réseau national, XEFI Ingénierie by IBO a su diversifier ses compétences et générer une valeur ajoutée significative dans le domaine de l'ingénierie informatique. Avec un chiffre d'affaires groupe de 355 M€ en 2023, réparti sur plus de 180 agences de proximité en France, Suisse, Belgique et Espagne, l'agence clermontoise s'inscrit dans un modèle MSP (Managed Services Provider), ciblant majoritairement les TPE, PME et collectivités locales de la région Auvergne.

L'activité de la structure se positionne autour d'une offre de services managés et d'intégration IT globale, structurée en quatre piliers majeurs :

- **L'infogérance et le support** : maintenance proactive, supervision des parcs informatiques et dépannage technique pour garantir le maintien en condition opérationnelle des infrastructures clients.
- **La cybersécurité** : sécurisation périmétrique et audits de vulnérabilités, s'appuyant notamment sur l'intégration de pare-feu de nouvelle génération (solutions partenaires comme Sophos).
- **Le Cloud et l'hébergement** : fourniture de solutions d'infrastructure hautement disponibles adossées aux datacenters certifiés du groupe XEFI, ainsi que l'administration d'environnements hybrides (Microsoft 365, Microsoft Entra Connect).
- **La vente et l'intégration de matériel** : fourniture, installation et configuration de postes de travail, serveurs et équipements réseau, accompagnée d'une offre de sauvegarde des données.

b. Ma mission

i. Constat

Le pôle XEFI Ingénierie Auvergne gère et supervise les infrastructures systèmes et réseaux d'un portefeuille de clients aux exigences opérationnelles variées. Parmi eux, une part importante est constituée de structures évoluant dans des secteurs critiques, notamment le secteur de la santé.

Ces établissements font face à deux besoins fondamentaux que XEFI se doit de garantir contractuellement :

1. La protection des données sensibles : soumises à un cadre réglementaire strict, ces structures représentent des cibles privilégiées pour les cyberattaques. La sécurité de leur annuaire Active Directory, qui centralise la gestion des droits et des accès au système d'information, est une priorité absolue.
2. La continuité de service : le secteur médical dépend d'une disponibilité continue de ses outils informatiques. Le moindre incident d'infrastructure peut impacter directement l'activité de l'établissement.

Face à ce constat, j'ai pris l'initiative, avec l'accord de l'entreprise, de concevoir un lab de maquettage isolé sur un serveur mis à disposition par XEFI. L'objectif était d'évaluer le

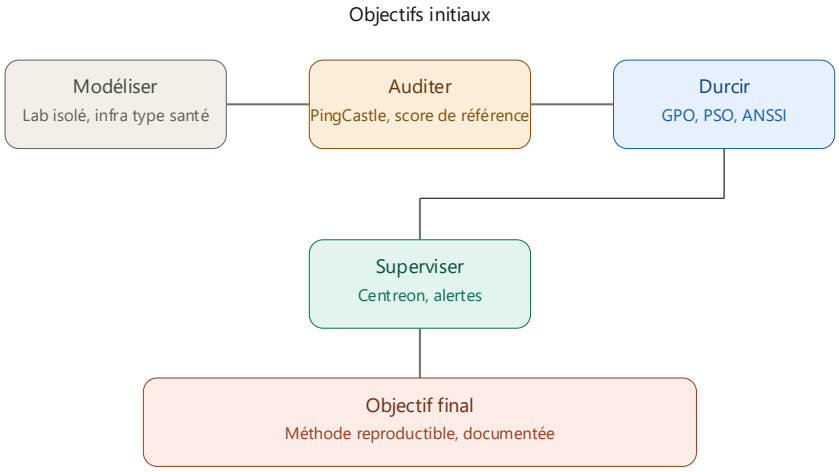
niveau de sécurité d'une infrastructure Active Directory type et de définir une méthodologie de durcissement, sans jamais intervenir sur les environnements de production des clients.

ii. Objectifs et périmètre de la mission

L'objectif de ce projet n'était pas d'intervenir sur l'infrastructure d'un client spécifique, mais de construire et d'expérimenter un processus d'audit et de durcissement Active Directory dans un environnement simulé, dont les résultats pourraient ensuite être réutilisés lors de futures interventions.

Le périmètre technique s'est structuré autour de trois axes :

- L'étude de l'existant : analyse des configurations types et des vulnérabilités génériques les plus courantes des environnements Active Directory en production (protocoles d'authentification, GPO, gestion des privilèges).
- La modélisation d'une infrastructure de référence : conception d'un laboratoire isolé simulant une infrastructure d'entreprise standard, intégrant les briques logicielles couramment déployées chez les clients (contrôleurs de domaine, pare-feu, interconnexion cloud).
- L'établissement d'une documentation de remédiation : validation technique d'une suite de correctifs au sein du laboratoire, afin de produire une documentation de durcissement exploitable par les équipes d'administration.



Cahier des charges

Le projet devait respecter un ensemble de contraintes et produire des livrables précis :

- **Non-intrusion :** ne jamais intervenir sur les infrastructures de production des clients ; travailler exclusivement sur un environnement de simulation isolé.
- **Représentativité :** modéliser une infrastructure fidèle à celle d'un établissement de santé, Active Directory, postes clients, pare-feu et supervision.
- **Conformité :** fonder les mesures de durcissement sur un référentiel reconnu, les recommandations de l'ANSSI.

- **Mesurabilité :** évaluer la sécurité par un audit chiffré, avant et après durcissement, afin d'objectiver l'amélioration.
- **Reproductibilité :** concevoir une démarche réutilisable sur d'autres environnements et la documenter.
- **Livrables :** un laboratoire fonctionnel, deux rapports d'audit (avant et après), les correctifs appliqués par GPO et PSO, une supervision opérationnelle et une documentation de remédiation.

iii. Architecture et environnement de simulation

Afin de mener cette étude sans intervenir sur les infrastructures de production des clients, un environnement de simulation isolé a été déployé sur un serveur physique mis à disposition par XEFI, virtualisé sous Proxmox VE.

Cet environnement modélise une infrastructure d'entreprise du secteur de la santé, structurée autour d'un annuaire Active Directory centralisé. Il se compose des éléments suivants :

- Un **contrôleur de domaine** sous Windows Server 2019, hébergeant le domaine sante-lab.local au niveau fonctionnel Windows Server 2016, constitue le cœur du système d'information simulé.
- Des **postes clients** sous Windows 10/11, joints au domaine, représentent les stations de travail utilisateurs typiques d'un cabinet médical ou d'une clinique. Le secteur de la santé se caractérise par la présence fréquente de périphériques spécialisés anciens, équipements d'imagerie médicale, automates de laboratoire, dispositifs de soins, dont les contraintes de compatibilité imposent parfois le maintien de protocoles ou de configurations obsolètes, constituant autant de vecteurs d'attaque potentiels.
- Un **pare-feu Sophos**, déployé en machine virtuelle, assure la segmentation réseau et la frontière entre le lab et l'extérieur, en cohérence avec les solutions effectivement déployées chez les clients XEFI.
- Une **machine virtuelle dédiée à la supervision Centreon**, sous Debian, chargée de surveiller la disponibilité et l'état des composants du lab via les protocoles SNMP et ICMP.

L'ensemble des machines virtuelles communique au sein d'un réseau local isolé (192.168.10.0/24), géré par un vSwitch Proxmox, sans exposition directe vers Internet.

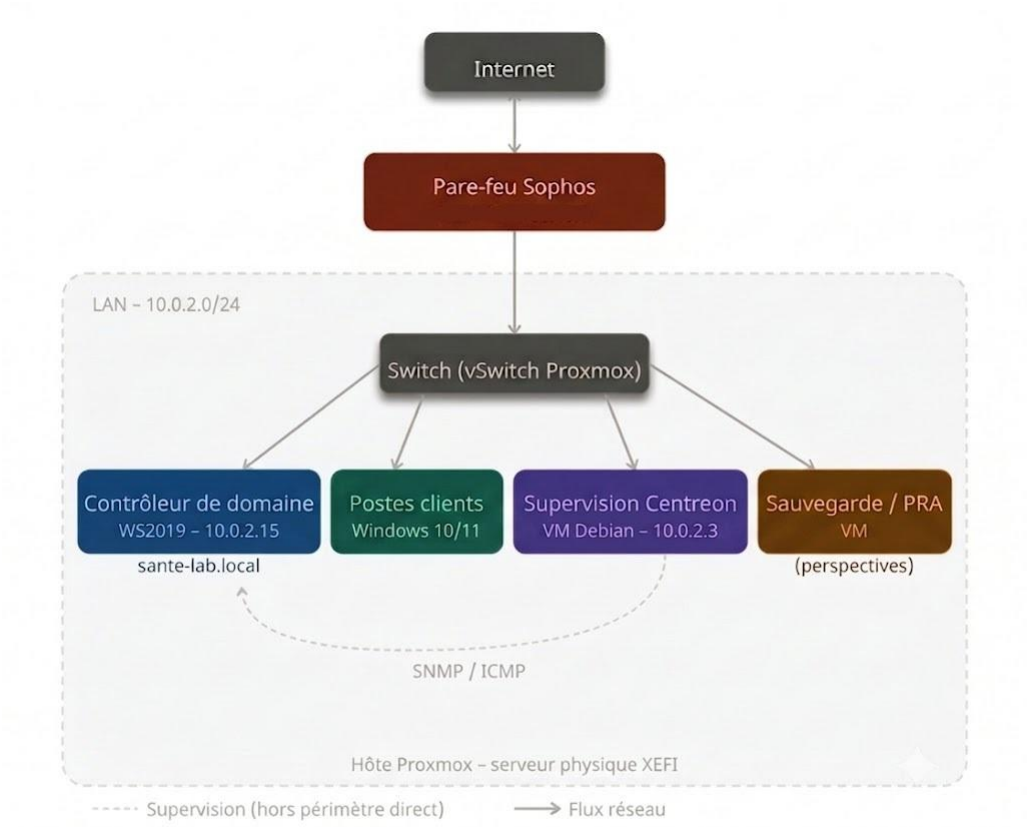


Figure 7 : Architecture de l'environnement de simulation : contrôleur de domaine, postes clients, pare-feu Sophos et supervision Centreon au sein d'un réseau isolé.

Afin de répondre à la problématique posée, le projet s'est structuré en quatre phases successives. La première phase consiste à introduire volontairement des vulnérabilités connues dans l'environnement, protocoles obsolètes, politique de mots de passe insuffisante, comptes sur-privilégiés, afin de constituer un état initial réaliste et représentatif d'une infrastructure non durcie. Un premier audit PingCastle est ensuite réalisé sur cet environnement dégradé, produisant un score de risque et un rapport de référence. La troisième phase applique l'ensemble des correctifs identifiés, via des stratégies de groupe (GPO) et des politiques de mots de passe affinées (PSO). Enfin, un second audit PingCastle vient mesurer l'amélioration obtenue, en parallèle de la mise en place de la supervision Centreon.

Organisation et déroulement du projet

Le projet s'est déroulé selon ces quatre phases successives, complétées par la mise en place d'une supervision active. Leur enchaînement logique structure l'ensemble de la réalisation décrite dans la partie suivante.

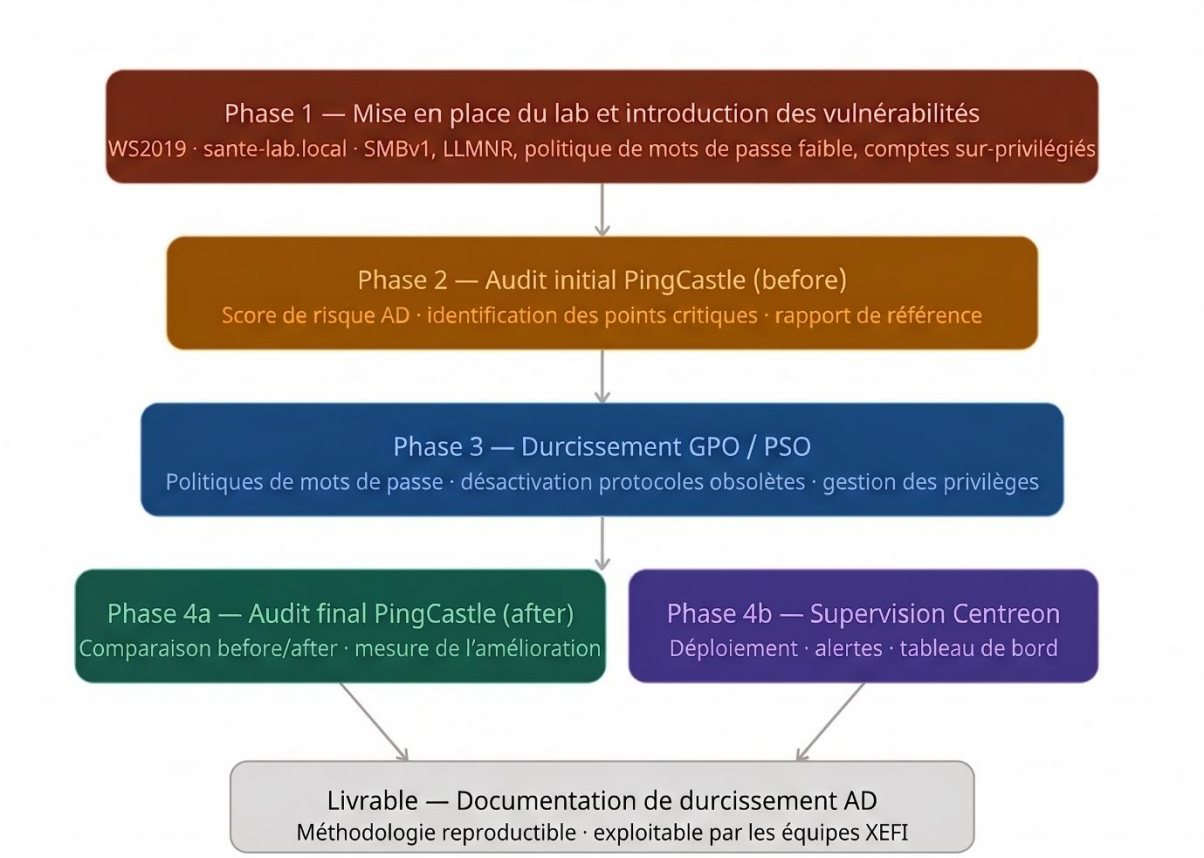


Figure 8 : Modèle d'architecture réseau sécurisée : segmentation en zones : pare-feu de périmètre Sophos, routeur/DMZ, switch cœur, zone LAN interne et zone DMZ publique.

iv. Outils utilisés

Durant ce projet, j'ai utilisé différents outils, que ce soit physiquement pour mettre en place l'architecture, ou en software pour la partie audit et supervision. Parmi eux, on retrouve notamment :

Audit et supervision
PingCastle, PingCastle est un outil gratuit et open source, développé par Vincent Le Toux. Il sert à évaluer le niveau de sécurité d'un annuaire Active Directory, en s'appuyant sur les recommandations de l'ANSSI.
Son fonctionnement est simple : il interroge l'annuaire via des requêtes LDAP, en lecture seule. Il n'exécute aucune attaque et ne modifie rien. C'est un exécutable autonome, sans installation.



Figure 9 : Logo pingcastle

L'analyse repose sur quatre catégories de risque :

- **Stale Objects** : comptes ou ordinateurs inactifs, mots de passe jamais renouvelés.
- **Privileged Accounts** : comptes avec des privilèges élevés, notamment les administrateurs du domaine.
- **Trusts** : relations d'approbation entre domaines.
- **Anomalies** : configurations atypiques ou suspectes.

Chaque catégorie obtient un score de 0 à 100. Le score global retenu est le maximum des quatre, pas la moyenne, une seule catégorie très dégradée suffit donc à faire apparaître tout le domaine comme à risque. L'échelle de lecture est la suivante : 0-30 posture correcte, 30-50 risques modérés, 50-70 risques significatifs, au-delà de 70 environnement très exposé. Le rapport final, au format HTML, liste chaque règle déclenchée avec les objets concernés et leur emplacement dans l'annuaire. Il est donc directement exploitable pour engager les corrections.

PingCastle reste néanmoins un outil d'analyse statique. Il ne fait aucun test d'intrusion réel et ne détecte rien en temps réel : il prend une photo de la configuration à un instant donné. Certains résultats peuvent être des faux positifs selon le contexte, d'où la nécessité d'une analyse humaine avant de corriger.

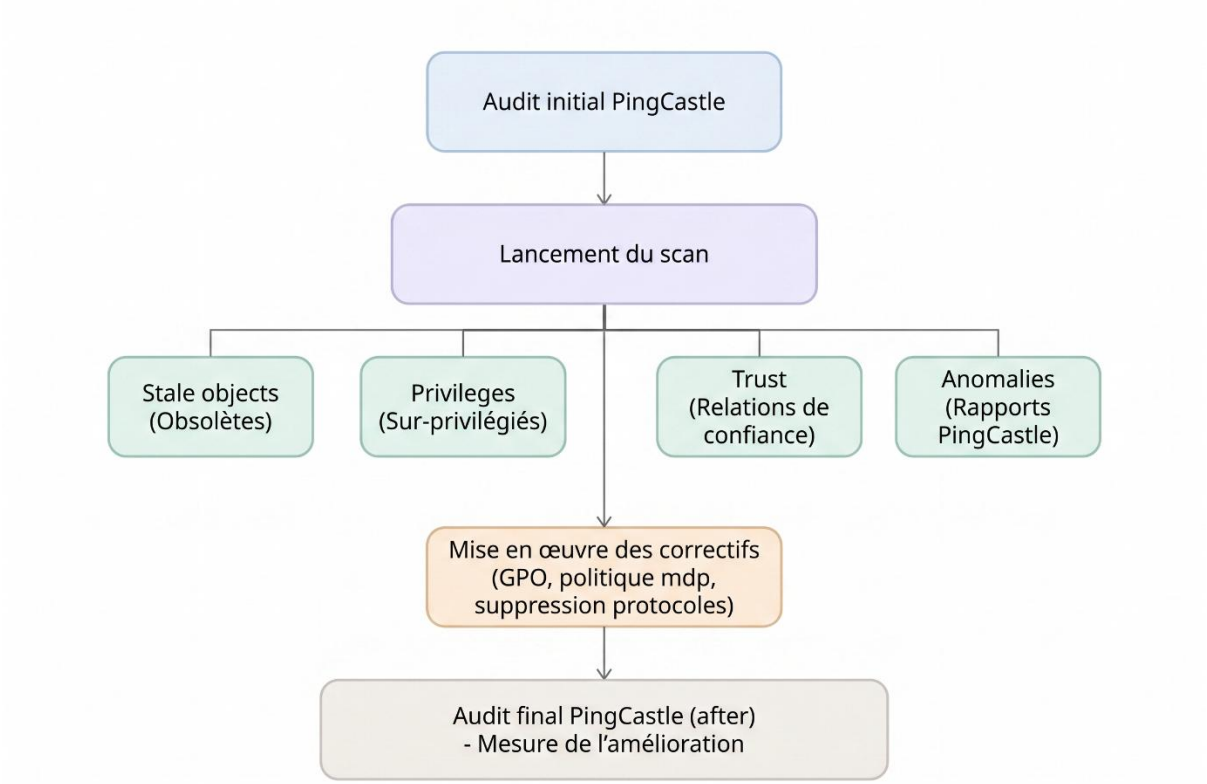


Figure 10 : Schéma du fonctionnement de ping castle

Le choix de cet outil plutôt qu'un autre s'explique par trois critères : c'est un outil gratuit et open source, ses règles s'appuient sur les recommandations de l'ANSSI, et son fonctionnement reste purement analytique, il ne touche à rien, ce qui le rend utilisable sans risque même sur un environnement sensible.

Centreon, Centreon est une plateforme de supervision open source. Elle sert à surveiller en continu l'état des composants d'un système d'information : serveurs, postes, services réseau, équipements.

Figure 11 : Logo Centreon

Son fonctionnement repose sur l'interrogation régulière des hôtes supervisés, via SNMP ou ICMP, pour récupérer des indicateurs (charge CPU, espace disque, état d'un service). Chaque indicateur est comparé à des seuils définis à l'avance. Tant que la valeur est normale, l'état est "OK". Au-delà d'un premier seuil, il passe à "Warning". Au-delà d'un second, à "Critical". Ces changements d'état génèrent des alertes, visibles sur un tableau de bord centralisé.

Dans le lab, Centreon a été déployé sur une VM dédiée sous Debian, et configuré pour superviser le contrôleur de domaine via SNMP. Ça reproduit le rôle que cet outil a chez les clients XEFI : détecter une dérive avant qu'elle ne devienne un appel client.

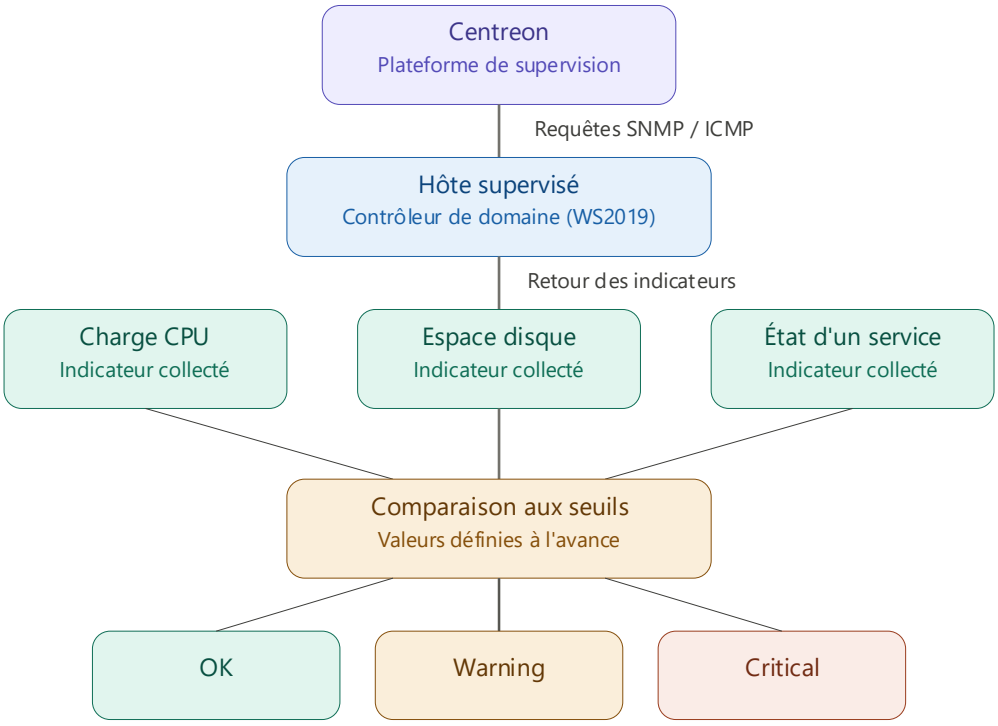


Figure 12 : Processus de collecte de métriques par Centreon sur la VM supervisée

Le choix de cet outil s'explique par la cohérence avec l'existant. C'est l'outil de supervision déjà utilisé par XEFI chez ses clients et permet une supervision centralisée des différents clients sur un seul serveur Centreon.
De plus cet outil est Open Source et fonctionne avec SNMP un protocole standard supporté par la grande majorité des équipements

Infrastructure

- **HP ProLiant DL360 Gen9**, Serveur physique mis à disposition par XEFI, support de l'ensemble des machines virtuelles du lab.



Figure 13 : Logo HP ProLiant DL360 Gen9

- **Proxmox VE**, Hyperviseur open source utilisé pour déployer et gérer l'ensemble des machines virtuelles de l'environnement de simulation.



Figure 14 : Logo Proxmox VE

Systèmes

- **Windows Server 2019**, Système d'exploitation du contrôleur de domaine, hébergeant les services Active Directory, DNS et DHCP du lab.



Figure 15 : Logo Windows Server 2019

- **Windows 10/11**, Systèmes des postes clients joints au domaine, simulant les stations de travail d'un environnement médical.
- **Debian**, Distribution Linux hébergeant la plateforme de supervision Centreon.



Figure 16 : Logo Debian

Réseau / Sécurité périmétrique

- **Sophos XG**, Pare-feu de nouvelle génération déployé en machine virtuelle, assurant la segmentation et le filtrage du trafic réseau du lab.



Figure 17 : Logo Sophos XG

- **Wireshark**, Outil d'analyse de trafic réseau, utilisé pour observer et valider les échanges de protocoles au sein du lab.



Figure 18 : Logo Wireshark

Administration AD

- **ADUC (Active Directory Users and Computers)**, Console MMC native de gestion des comptes utilisateurs, groupes et unités organisationnelles.
- **GPMC (Group Policy Management Console)**, Console de création, de liaison et de déploiement des stratégies de groupe (GPO) sur le domaine.
- **PowerShell**, Utilisé pour la création et la configuration des politiques de mots de passe affinées (PSO) ainsi que pour l'automatisation de certaines tâches d'administration.
- **Observateur d'événements (Event Viewer)**, Outil natif Windows utilisé pour l'analyse des journaux d'événements Active Directory, notamment la détection de tentatives d'authentification et de verrouillages de comptes.

2. Réalisation technique

Pour répondre à la problématique posée en introduction, j'ai suivi une démarche en trois étapes : modéliser, auditer, corriger. D'abord, modéliser une infrastructure de référence isolée, représentative des environnements gérés par XEFI. Ensuite, l'auditer pour mesurer

son niveau de sécurité. Enfin, appliquer des correctifs et vérifier leur effet. C'est un processus réutilisable, que l'agence peut appliquer à ses différents annuaires.

Cette première sous-partie traite de la modélisation de l'infrastructure, et de la mise en place d'un état de départ volontairement vulnérable

a. Mise en place du laboratoire et introduction des vulnérabilités

i. Choix et rôle de l'environnement de virtualisation

Le projet a été réalisé en LAB afin de ne jamais agir sur un réseau client réel. Il a donc fallu donc reproduire une infrastructure d'entreprise dans un environnement isolé. Deux exigences guident ce choix. La première est l'isolation : un environnement volontairement vulnérable ne doit jamais pouvoir atteindre un réseau de production ou Internet. La seconde est la réversibilité : pouvoir revenir à un état antérieur après chaque modification, pour comparer un avant et un après sans tout reconstruire.

Pour ça, j'ai utilisé Proxmox VE. Un hyperviseur est un logiciel qui crée et exécute des machines virtuelles. Une machine virtuelle (VM) est un ordinateur complet simulé par logiciel : elle possède un disque, de la mémoire et un système d'exploitation, mais n'existe pas physiquement. Proxmox est un hyperviseur de type 1, c'est-à-dire qu'il s'installe directement sur le matériel, sans système d'exploitation intermédiaire.

Son rôle est double. Il divise un serveur physique unique en plusieurs machines virtuelles indépendantes, et alloue à chacune les ressources dont elle a besoin : processeur, mémoire, stockage. Une seule machine physique suffit ainsi à simuler un réseau d'entreprise complet, tout en gardant l'ensemble cloisonné.

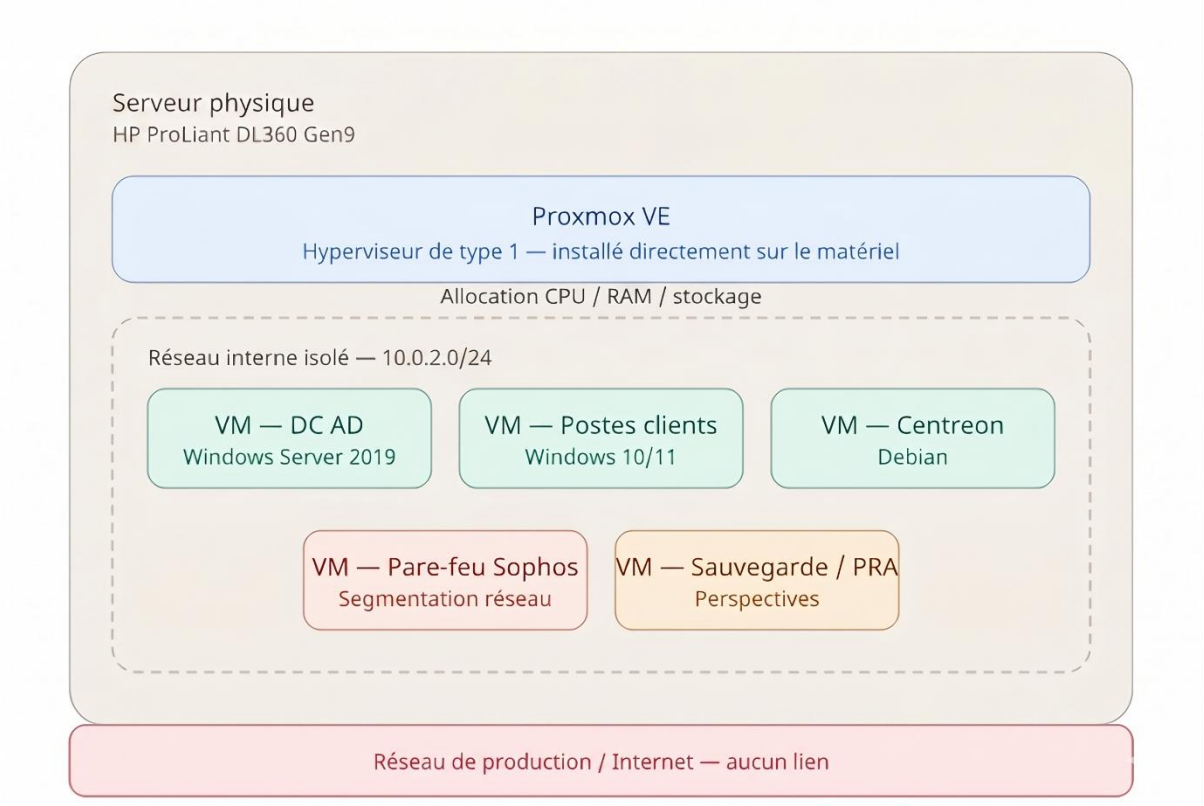


Figure 19 : Architecture technique du Lab sur un hyperviseur

L'environnement a été configuré en réseau isolé. Les machines communiquent entre elles, mais le domaine vulnérable n'est jamais exposé vers l'extérieur. Ce choix découle directement de la nature du projet : introduire volontairement des failles impose de ne jamais les rendre accessibles.

ii. Déploiement du contrôleur de domaine

Le cœur de l'infrastructure est un contrôleur de domaine sous Windows Server 2019.

Le déploiement s'est fait en trois temps.

D'abord, j'ai installé Windows Server 2019 en édition complète avec interface graphique, pour pouvoir manipuler les consoles d’administration plus facilement

Ensuite, j'ai ajouté le rôle Active Directory Domain Services et enfin, j'ai promu le serveur en contrôleur de domaine, en créant une nouvelle forêt dont le domaine racine est sante-lab.local.

Lors de la promotion, le rôle DNS s'installe automatiquement, car la résolution de noms est indispensable au fonctionnement d'Active Directory.

```
PS C:\Users\Administrateur> Get-ADDomain


AllowedDNSSuffixes                : {}
ChildDomains                      : {}
ComputersContainer                : CN=Computers,DC=sante-lab,DC=local
DeletedObjectsContainer           : CN=Deleted Objects,DC=sante-lab,DC=local
DistinguishedName                 : DC=sante-lab,DC=local
DNSRoot                           : sante-lab.local
DomainControllersContainer        : OU=Domain Controllers,DC=sante-lab,DC=local
DomainMode                        : Windows2016Domain
DomainSID                         : S-1-5-21-3483370294-805444570-253369830
ForeignSecurityPrincipalsContainer : CN=ForeignSecurityPrincipals,DC=sante-lab,DC=local
Forest                            : sante-lab.local
InfrastructureMaster              : WIN-DVEFOKPP7UL.sante-lab.local
LastLogonReplicationInterval      :
LinkedGroupPolicyObjects          : {cn={91508E14-264F-4785-A57E-4396F8E5C8A3},cn=policies,cn=system,DC=sante-lab,DC=l
                                    ocal, CN={31B2F340-016D-11D2-945F-00C04FB984F9},CN=Policies,CN=System,DC=sante-lab
                                    ,DC=local}
LostAndFoundContainer             : CN=LostAndFound,DC=sante-lab,DC=local
ManagedBy                         :
Name                              : sante-lab
NetBIOSName                       : SANTE-LAB
ObjectClass                       : domainDNS
ObjectGUID                        : 694a84c8-daf3-431a-b1de-6add2f92a13a
ParentDomain                      :
PDCEmulator                       : WIN-DVEFOKPP7UL.sante-lab.local
```

Figure 20 : Validation de la promotion de la VM en contrôleur de domaine

iii. Introduction volontaire des vulnérabilités

L'objectif est de constituer un état de départ réaliste. Plutôt que de partir d'un domaine déjà sécurisé, j'ai reproduit des configurations couramment rencontrées sur des infrastructures vieillissantes souffrant d'un déficit de maintenance. Ces quatres vulnérabilités ne sont pas choisies au hasard : elles couvrent trois des quatre catégories analysées par PingCastle (présenté plus haut), pour constituer un état initial que l'audit pourra mesurer de façon pertinente.

SMBv1. SMB est le protocole de partage de fichiers de Windows. Sa première version est obsolète : c'est elle qu'ont exploité les rançongiciels WannaCry et NotPetya en 2017 pour se propager. Pourtant, des équipements anciens, imprimantes, automates de laboratoire, vieux logiciels métiers, ne savent parfois communiquer qu'avec elle. Un technicien la réactive pour dépanner, et l'oubli s'installe. C'est ce protocole que j'ai activé sur le domaine.

LLMNR. Ce protocole sert à résoudre des noms réseau quand le DNS échoue. Son problème : un attaquant présent sur le réseau peut répondre à la place d'une machine légitime, et récupérer des empreintes de mots de passe. Je n'ai eu aucune manipulation à faire pour créer cette faille, LLMNR est actif par défaut sur Windows, et en petite structure il n'est presque jamais désactivé. Le laisser en l'état reflète donc fidèlement un parc non administré.

Politique de mots de passe. Je l'ai affaiblie : longueur minimale ramenée à sept caractères, expiration relâchée. Ça facilite les attaques par force brute. Ce relâchement n'a rien de théorique : il correspond à des situations où la politique est abaissée à la demande d'utilisateurs qui peinent à retenir leurs mots de passe.

Compte inactif. Le compte ancien.admin représente celui d'un administrateur ayant quitté la structure, jamais désactivé après son départ. Personne ne surveille les connexions d'un compte censé ne plus servir, ce qui en fait une porte d'entrée invisible. C'est un défaut classique de gestion du cycle de vie des comptes.

Vulnérabilité	Risque associé	Catégorie d'audit visée dans ping castle
SMBv1 activé	Protocole obsolète (WannaCry, EternalBlue)	Anomalies
LLMNR actif	Capture d'empreintes de mots de passe	Anomalies
Mots de passe faibles	Force brute facilitée	Anomalies
ancien.admin actif	Compte obsolète non désactivé	Objets périmés

Figure 21 : Tableau des vulnérabilités

L'infrastructure de référence est maintenant en place, et volontairement dégradée. J'ai pris un instantané Proxmox, nommé AVANT-durcissement, pour figer cet état et pouvoir comparer après correction. L'audit de cet environnement, présenté ci-dessous, en mesure le niveau de risque.

b. Audit initial de l'infrastructure

L'infrastructure en place, il faut maintenant mesurer son niveau de sécurité. Cette mesure doit être objective : pas une impression, mais une analyse outillée et reproductible. C'est la seule façon de comparer ensuite l'avant et l'après de façon fiable. L'outil que j'ai retenu est PingCastle.

i. Présentation de l'outil PingCastle

Son principal intérêt, et la raison de ce choix, est qu'il ne signale pas des problèmes au hasard : il confronte la configuration de l'annuaire aux recommandations de l'ANSSI.

Qu'est-ce que l'ANSSI ?

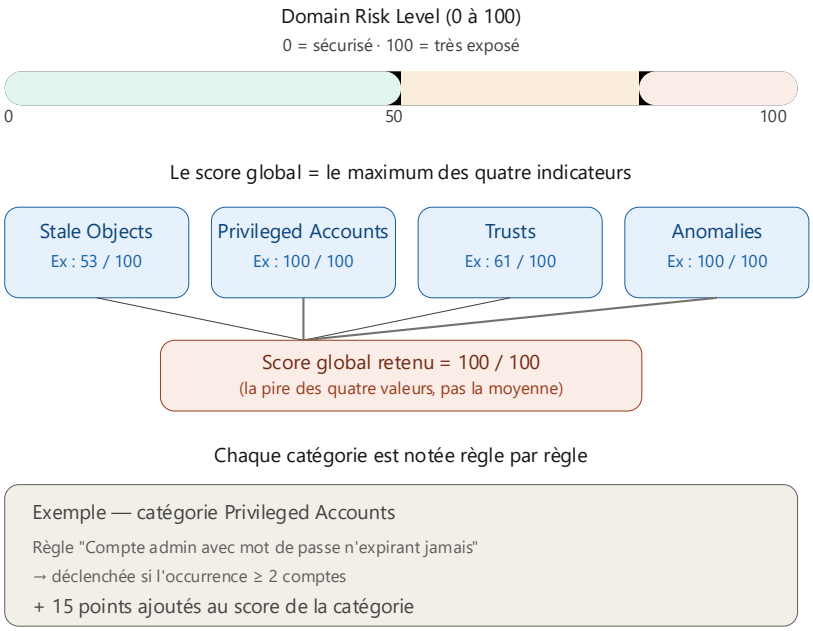
L'ANSSI, Agence nationale de la sécurité des systèmes d'information, est l'autorité française de référence en cybersécurité. Créée en 2009, elle est rattachée aux services du Premier ministre, sous l'autorité du secrétaire général de la défense et de la sécurité nationale. Sa mission est de protéger les systèmes d'information de l'État et des entreprises.
Elle publie des guides de recommandations qui font autorité en France : ce sont eux que suivent les administrations et la plupart des prestataires informatiques. S'appuyer sur l'ANSSI, c'est donc fonder son travail sur un référentiel officiel et reconnu, plutôt que sur des choix personnels. C'est ce qui donne sa légitimité à une démarche de durcissement.

Un dernier point a motivé ce choix : PingCastle fonctionne avec un compte utilisateur standard du domaine, sans droits d'administration. La lecture des objets de l'annuaire est accessible à tout utilisateur authentifié, ce qui répond directement à la contrainte du projet, auditer sans perturber la production.

ii. Le modèle de score

Le score global, le Domain Risk Level, correspond au maximum des quatre catégories présentées plus haut, pas à leur moyenne. Sur le rapport officiel de démonstration de PingCastle, par exemple, les quatre catégories sont notées séparément (53, 100, 61 et 100 sur 100), et le score global retenu est 100 : c'est la pire des quatre.

À l'intérieur de chaque catégorie, le détail se fait règle par règle. Chaque règle ajoute un nombre de points fixe si elle est déclenchée, par exemple, la présence d'au moins deux comptes administrateurs avec un mot de passe qui n'expire jamais ajoute 15 points à la catégorie Privileged Accounts. Plus une catégorie cumule de règles déclenchées, plus son score grimpe, jusqu'à un maximum de 100.



Concrètement, ça veut dire qu'il ne sert à rien de corriger trois catégories si le quatrième reste mauvais : c'est elle qui fixe la note. La priorité va donc à la catégorie qui domine le score, c'est elle qui oriente le plan de durcissement.

iii. Résultats de l'audit initial

L'environnement sante-lab.local étant prêt et volontairement dégradé, je lance PingCastle pour mesurer son niveau de risque réel.

L'audit donne un Domain Risk Level (score retiré de cette version), avec 29 règles déclenchées au total. Le résultat traduit un domaine clairement non durci, ce qui est cohérent avec l'état volontairement dégradé constitué à l'étape précédente.



Figure 22 : Export du résultat ping Caste avant durcissement

Indicateur	Score	Règles déclenchées
Anomalies	—	—
Privileged Accounts	—	—
Stale Objects	—	—
Trusts	—	—

Domain Risk Level (global) —

Figure 23 : Tableau récapulatif du résultat ping Castle avant durcissement

Plusieurs constats ressortent de ce tableau.
Le score global vient de la catégorie Anomalies, la plus élevée des quatre. C'est donc elle qu'il faudra traiter en priorité pour faire baisser la note globale. Le plus gros contributeur est l'absence de LAPS (Local Administrator Password Solution), qui ajoute 15 points à elle seule. Suivent l'audit insuffisant sur le contrôleur de domaine, le service Spouleur d'impression accessible à distance, et la politique de mots de passe affaiblie, c'est elle qui correspond à la vulnérabilité introduite, les autres points venant de la configuration par défaut d'un domaine fraîchement installé.

La catégorie Privileged Accounts compte seulement 5 règles. La plus pénalisante (20 points) concerne des comptes administrateurs sans la protection contre la délégation. Les autres règles concernent l'absence de la corbeille Active Directory, le groupe Schema Admins non vide, et des comptes admin hors du groupe Protected Users. Ces points relèvent de la configuration par défaut du domaine, pas de manipulations spécifiques.
La catégorie Stale Objects compte 10 règles. C'est ici que se trouve la vulnérabilité SMBv1 (10 points), accompagnée de l'autorisation NTLMv1/LM (15 points), de la possibilité pour un utilisateur standard d'ajouter des machines au domaine (10 points), et d'une déclaration de sous-réseau incomplète (5 points).

Enfin, Trusts est à 0, et c'est attendu : le laboratoire ne comporte qu'un seul domaine, sans relation d'approbation vers un autre annuaire. Cet indicateur restera nul tout au long du projet.
Ce score est la référence de départ. Il sera comparé, après application des correctifs, au score obtenu sur le même environnement. La sous-partie suivante détaille ces correctifs.

c. Durcissement de l'infrastructure

L'audit a identifié les points faibles et désigné la catégorie à traiter en priorité. Reste à appliquer les correctifs. Chacun vise une ou plusieurs des vulnérabilités introduites, et je l'applique autant que possible de façon centralisée, par stratégie de groupe (GPO), plutôt que machine par machine. Ce choix est volontaire : dans un parc réel, une correction appliquée par GPO se propage automatiquement à toutes les machines du domaine. C'est cohérent avec la logique de processus réutilisable visée par le projet.

Qu'est-ce qu'une GPO ?
Une stratégie de groupe (Group Policy Object) est un ensemble de règles de configuration appliquées de façon centralisée à tous les ordinateurs et utilisateurs d'un domaine, ou d'une partie de celui-ci. Plutôt que de configurer chaque poste individuellement, l'administrateur définit la règle une fois sur le contrôleur de domaine, et elle s'applique partout. C'est l'outil principal d'administration et de durcissement d'un parc Windows

i. Désactivation des protocoles obsolètes

J'ai désactivé SMBv1 par GPO, sur l'ensemble du domaine. La désactivation porte à la fois sur la capacité à utiliser le protocole et sur celle à y répondre. Un redémarrage des machines est nécessaire, car la modification touche le pilote du protocole. J'ai profité de la même stratégie pour activer la signature des échanges SMB : elle protège contre les attaques de type "homme du milieu" en garantissant l'intégrité des communications, et fonctionne avec les versions modernes SMBv2 et SMBv3 qui prennent le relais.
J'ai ensuite désactivé LLMNR, là encore par GPO. Une fois la stratégie appliquée, les machines du domaine cessent d'utiliser ce protocole et ne peuvent plus être trompées par une fausse réponse sur le réseau.

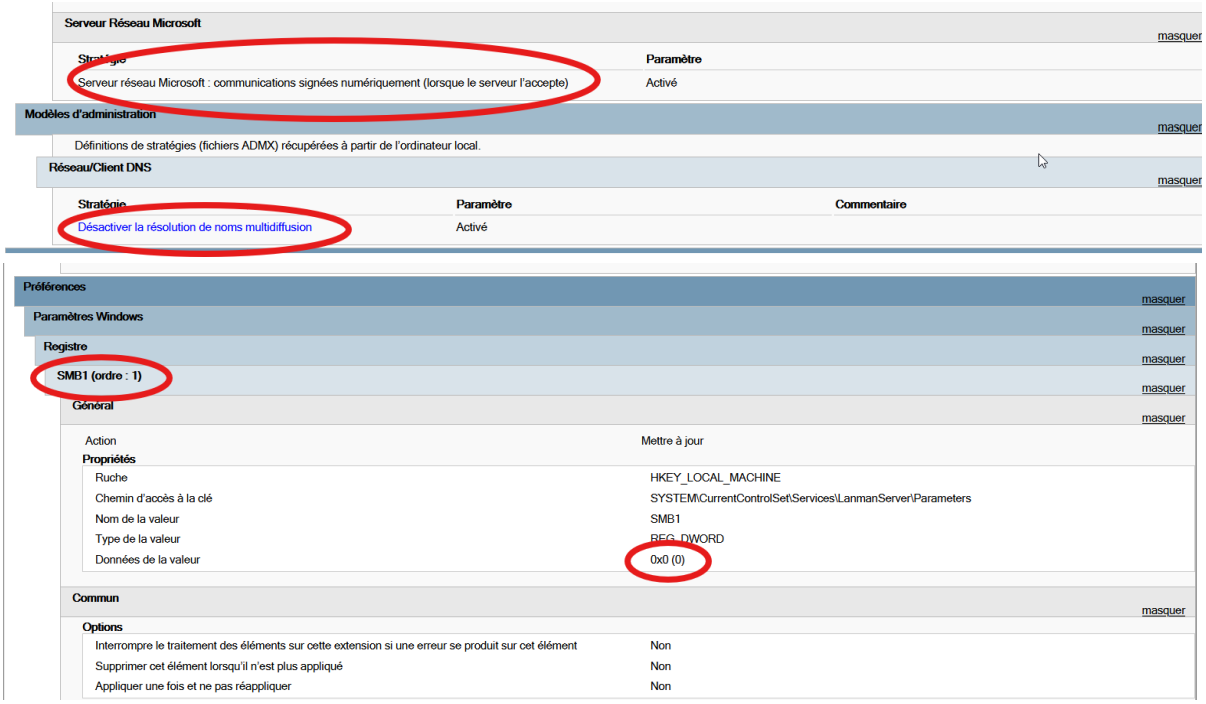


Figure 24 : SMBv1 désactivé + signature SMB activée + LLMNR désactivé via GPO

ii. Renforcement de la politique de mots de passe

C'est sur cette partie que la démarche de recherche a été la plus poussée. Plutôt que de choisir des valeurs au hasard, je me suis appuyé sur le guide de l'ANSSI intitulé « Recommandations relatives à l'authentification multifacteur et aux mots de passe » (version 2.0, octobre 2021). Ce guide fait référence en France, et fonder mes choix dessus garantit qu'ils sont justifiés et défendables, et non le fruit d'une préférence personnelle.

Un point mérite d'être souligné, car il va à l'encontre d'une idée reçue. Pendant longtemps, la règle était de forcer le changement de mot de passe tous les quelques mois. L'ANSSI a changé de position : pour les comptes utilisateurs standards, si les mots de passe sont assez robustes, elle recommande désormais de ne plus imposer d'expiration. La raison est simple : obligés de changer souvent, les utilisateurs se contentent d'incrémenter leur mot de passe (motdepasse1, motdepasse2…), un comportement que les attaquants connaissent et exploitent. J'ai donc appliqué cette logique, ce qui montre que le durcissement ne consiste pas à empiler des contraintes, mais à appliquer les bonnes.

J'ai retenu une approche à deux niveaux, conforme au guide.
Le premier niveau concerne tous les utilisateurs. La politique par défaut du domaine, que j'avais affaiblie, est rétablie : longueur minimale portée à quatorze caractères, complexité exigée, et pas d'expiration imposée, conformément à la recommandation de l'ANSSI pour les comptes non sensibles.

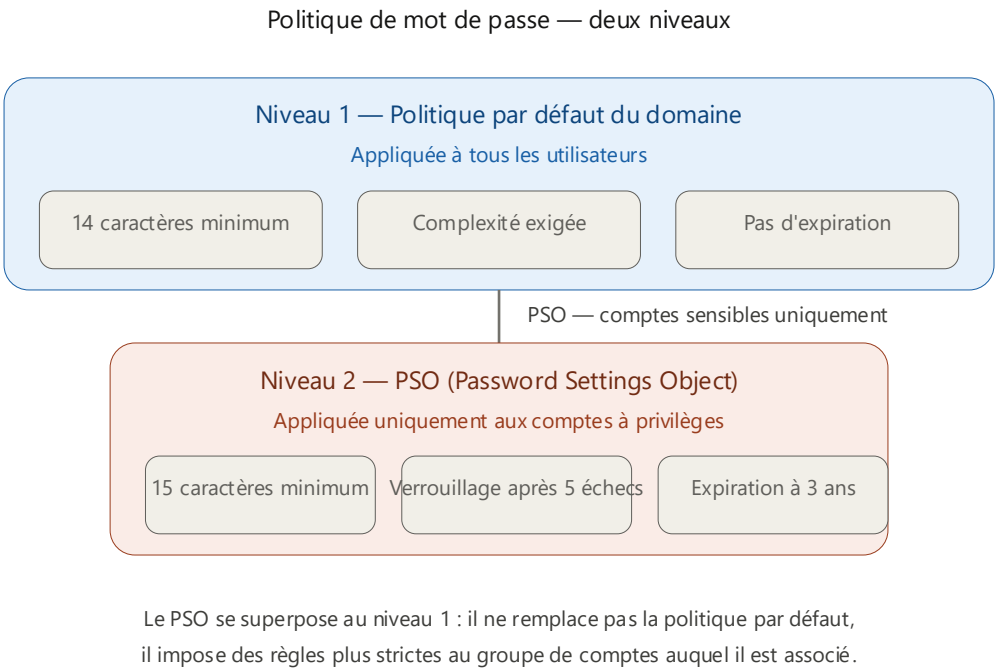


Figure 25 : Schéma de politique de mot de passe recommandé par l'ANSSI

Le second niveau concerne les comptes à privilèges, qui demandent une protection plus stricte. Pour eux, j'ai créé une politique de mot de passe affinée, un PSO (Password Settings Object).

La politique de mot de passe affinée (PSO)

Par défaut, un domaine Active Directory ne peut appliquer qu'une seule politique de mot de passe à tous ses utilisateurs. Le PSO lève cette limite : il permet d'imposer une politique plus stricte à un groupe précis. On crée un objet de paramètres, on y définit des règles plus exigeantes, puis on l'associe à un groupe. C'est l'outil adapté pour soumettre les administrateurs à des exigences supérieures à celles du reste du parc.
En pratique, j'ai créé un groupe réunissant les comptes sensibles, puis je lui ai associé le PSO. Les administrateurs se voient imposer un mot de passe d'au moins quinze caractères, un verrouillage du compte après cinq échecs de connexion, et une expiration de trois ans, la borne haute recommandée par l'ANSSI pour les comptes à privilèges. La logique est simple : plus un compte est puissant, plus sa protection doit être stricte.

La notion d'entropie

Pour mesurer la robustesse d'un mot de passe, l'ANSSI ne raisonne pas en nombre de caractères mais en entropie, exprimée en bits. L'entropie mesure le degré d'imprévisibilité d'un secret : plus elle est élevée, plus le mot de passe est difficile à deviner. On peut l'estimer ainsi : un mot de passe de longueur L, pris dans un alphabet de N caractères possibles, offre N puissance L combinaisons. Son entropie vaut alors L × $\log_2(N)$ bits. Par exemple, un mot de passe de 12 caractères choisis parmi 94

caractères imprimables atteint environ $12 \times \log_2(94) \approx 79$ bits, soit le seuil de 80 bits recommandé par l'ANSSI. Cette formule explique pourquoi l'agence privilégie aujourd'hui la longueur : allonger le mot de passe augmente l'entropie plus efficacement que d'ajouter des règles de complexité.

iii. Correction de la gestion des comptes et des privilèges

Sur un annuaire réel, on ne connaît pas à l'avance les comptes problématiques. Il faut d'abord les détecter. J'ai donc utilisé une commande PowerShell pour repérer les comptes utilisateurs sans connexion depuis 90 jours, en ne gardant que ceux encore activés :

```
PS C:\Users\Administrateur> Search-ADAccount -UsersOnly -AccountInactive -TimeSpan 90.00:00:00 | Where-Object { $_.Enabled -eq $true }


AccountExpirationDate :
DistinguishedName     : CN=ancien.admin,CN=Users,DC=sante-lab,DC=local
Enabled               : True
LastLogonDate         :
LockedOut             : False
Name                  : ancien.admin
ObjectClass           : user
ObjectGUID            : c3c83648-cca4-4059-8d7f-f13b4315d81e
PasswordExpired       : False
PasswordNeverExpires  : True
SamAccountName        : ancien.admin
SID                   : S-1-5-21-3483370294-805444570-253369830-1103
UserPrincipalName     : ancien.admin@sante-lab.local

AccountExpirationDate :
DistinguishedName     : CN=svc.backup,CN=Users,DC=sante-lab,DC=local
Enabled               : True
LastLogonDate         :
LockedOut             : False
Name                  : svc.backup
ObjectClass           : user
ObjectGUID            : f262476d-598b-48be-bc44-2913ed701639
PasswordExpired       : False
PasswordNeverExpires  : True
SamAccountName        : svc.backup
SID                   : S-1-5-21-3483370294-805444570-253369830-1105
UserPrincipalName     : svc.backup@sante-lab.local



PS C:\Users\Administrateur>
```

Figure 26 : Commande powershell pour retrouver les comptes inactifs

On peut y voir deux comptes, un compte ancien.admin qui est clairement un compte admin non utilisé et on voit un deuxième compte nommé svc.backup, on pourrait être tenté de le supprimer mais attention il ne faut pas non plus supprimer tous les comptes.

Cela pourrait être un compte de service utilisé pour un applicatif métier qui ne déclenche pas pour autant une connexion, ce qui le rendrait primordiale pour l'activité mais le ferait tout de même remonter dans les inactifs.

Il parait donc cohérent de désactiver le compte ancien.admin et laisser le svc.backup à défaut de savoir son rôle exact.

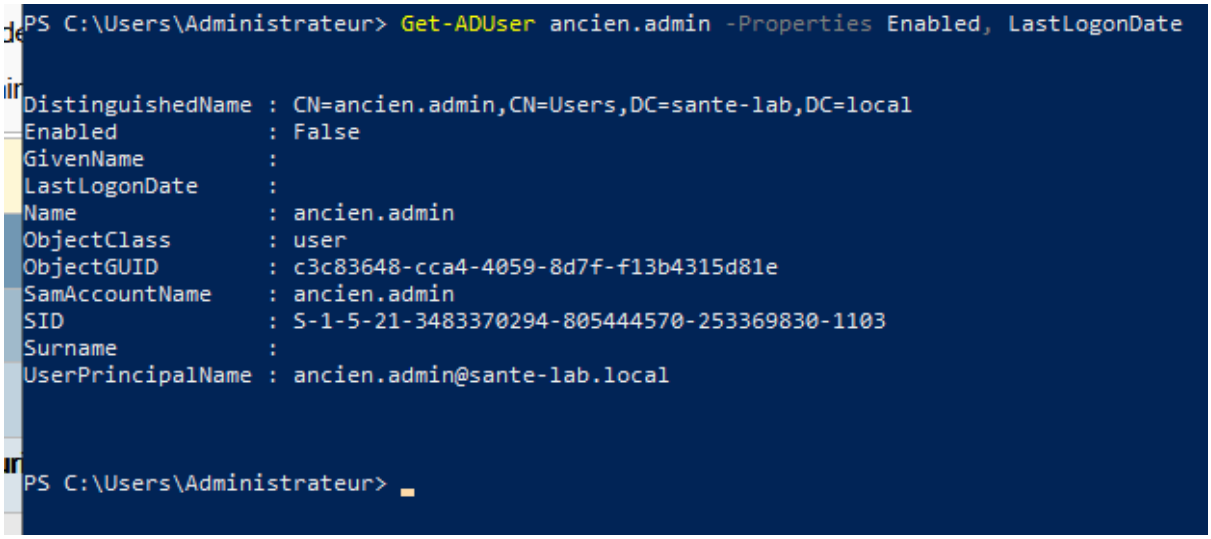


Figure 27 : Désactivation d'un compte admin inactif

Un compte de service, par exemple, peut très bien ne jamais se connecter mais ne doit pas être désactivé pour autant

Désactiver tout ce qui est détecté, sans vérifier, risquerait de casser des services en production. La bonne méthode reste : détecter, vérifier à la main, puis désactiver seulement ce qui est confirmé.

iv. Vérification des correctifs

Le durcissement ne s'arrête pas à l'application des correctifs : il faut vérifier que chacun fonctionne vraiment.

J'ai donc contrôlé chaque correctif un par un : SMBv1 désactivé, nouvelle politique de mots de passe appliquée, ancien.admin désactivé. Tout est confirmé.
L'environnement est prêt pour le second audit, comparé à l'audit initial dans la sous-partie suivante.

d. Audit final et comparaison

Après ce durcissement je peux donc relancer PingCastle sur l'environnement sécurisé et cela permet donc de faire une comparaison avant/après

i. Comparaison des scores

Après durcissement, le Domain Risk Level baisse dans chacune des quatre catégories (chiffres retirés de cette version).



	Avant	Après
Indicateur		
Anomalies	—	—
Privileged Accounts	—	—
Stale Objects	—	—
Trusts	—	—
Domain Risk Level (global)	**—**	**—**

Scores retirés de cette version publique.

Scores retirés de cette version publique.

Scores retirés de cette version publique.

Scores retirés de cette version publique.
Scores retirés de cette version publique.
Scores retirés de cette version publique.

ii. Ce qui n'a pas été corrigé, et pourquoi

Le score a diminué mais n'est pas à zéro, et ça s'explique par plusieurs facteurs.

Après durcissement, c'est toujours Anomalies qui fixe la note globale. PingCastle teste des dizaines de points de configuration. J'ai corrigé les vulnérabilités introduites volontairement, mais il reste des règles déclenchées par la configuration par défaut d'un Windows Server fraîchement installé.
Certains points relèvent de bonnes pratiques avancées : la rotation régulière de la clé krbtgt (le compte interne d'authentification du domaine), ou LAPS pour gérer les mots de passe

administrateurs locaux. D'autres règles ne sont pas pertinentes dans un lab à un seul serveur.

Un score à zéro n'existe pas en pratique. Durcir un AD, c'est aussi faire des compromis entre sécurité et usage : certaines configurations recommandées par PingCastle peuvent compliquer l'administration ou la compatibilité avec d'anciens équipements, et chaque correctif doit être pesé par rapport à son impact réel. L'objectif est de réduire le risque sur des points concrets, avec une méthode reproductible. C'est ce qu'on obtient ici : 10 points de moins, sur des vulnérabilités identifiées et corrigées une par une. Les points restants donnent une base pour une prochaine itération.

e. Mise en place de la supervision

Après avoir sécurisé l'infrastructure, une autre étape importante est la supervision. Le but : détecter rapidement les anomalies sur les équipements, et pouvoir réagir avant que ça devienne un problème pour l'utilisateur. L'outil retenu pour ça est Centreon.

i. Le principe de la supervision

Le principe de la supervision, c'est de surveiller l'état d'une machine en continu, et pas juste une fois.
Il y a donc deux acteurs : la machine surveillée — ici le contrôleur de domaine — et le serveur de supervision, Centreon. Centreon interroge régulièrement le contrôleur de domaine pour savoir comment il se porte : charge CPU, espace disque, services actifs. Ces questions sont posées à intervalle régulier, ce qui permet de suivre une évolution dans le temps et de détecter un problème dès qu'une valeur dépasse un seuil normal.
Pour ça, les deux machines communiquent avec un protocole commun : SNMP (Simple Network Management Protocol), un standard fait pour ce genre d'échange. Centreon envoie une question — par exemple "quel est ton taux CPU ?" — et le contrôleur de domaine répond avec la valeur. Pour pouvoir répondre, il faut qu'un agent SNMP tourne sur la machine surveillée, c'est lui qui écoute les questions et y répond.

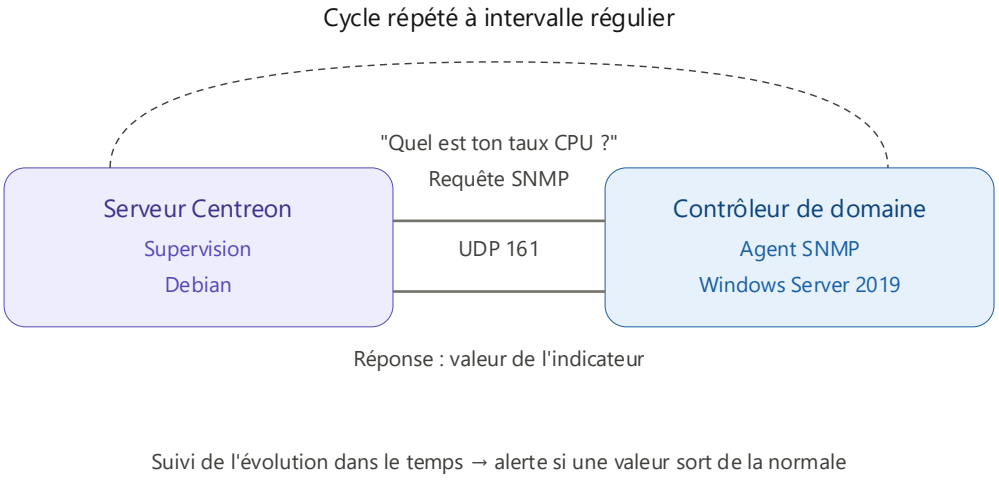


Figure 28 : Schéma des requêtes Centreon

La mise en place s'est faite en trois temps : installer Centreon, configurer l'agent SNMP sur le contrôleur de domaine, puis définir ce qu'on veut surveiller.

ii. Installation du serveur de supervision

Centreon a été installé sur une machine virtuelle dédiée, sous Debian 12.

J'ai choisi une machine virtuelle dédiée sous Debian, pour sa légèreté et sa stabilité, en m'assurant qu'elle n'a que ce rôle de supervision. Cette machine n'a que le rôle de superviseur, rien d'autres n'est mis en place dessus.

L'installation s'est appuyée sur les paquets officiels de Centreon, après ajout des dépôts MariaDB et Centreon au système.

Le paquet centreon-mariadb installe et configure la base de données qui stockera l'historique des mesures, et le paquet centreon installe l'interface web, le moteur de supervision, et leurs dépendances (PHP, Apache). Le détail des commandes est en annexe.

Une fois l'installation terminée, plusieurs services tournent en parallèle : MariaDB pour la base de données, le moteur de supervision (centengine), le broker de données (cbd), et le demon SNMP (snmpd).

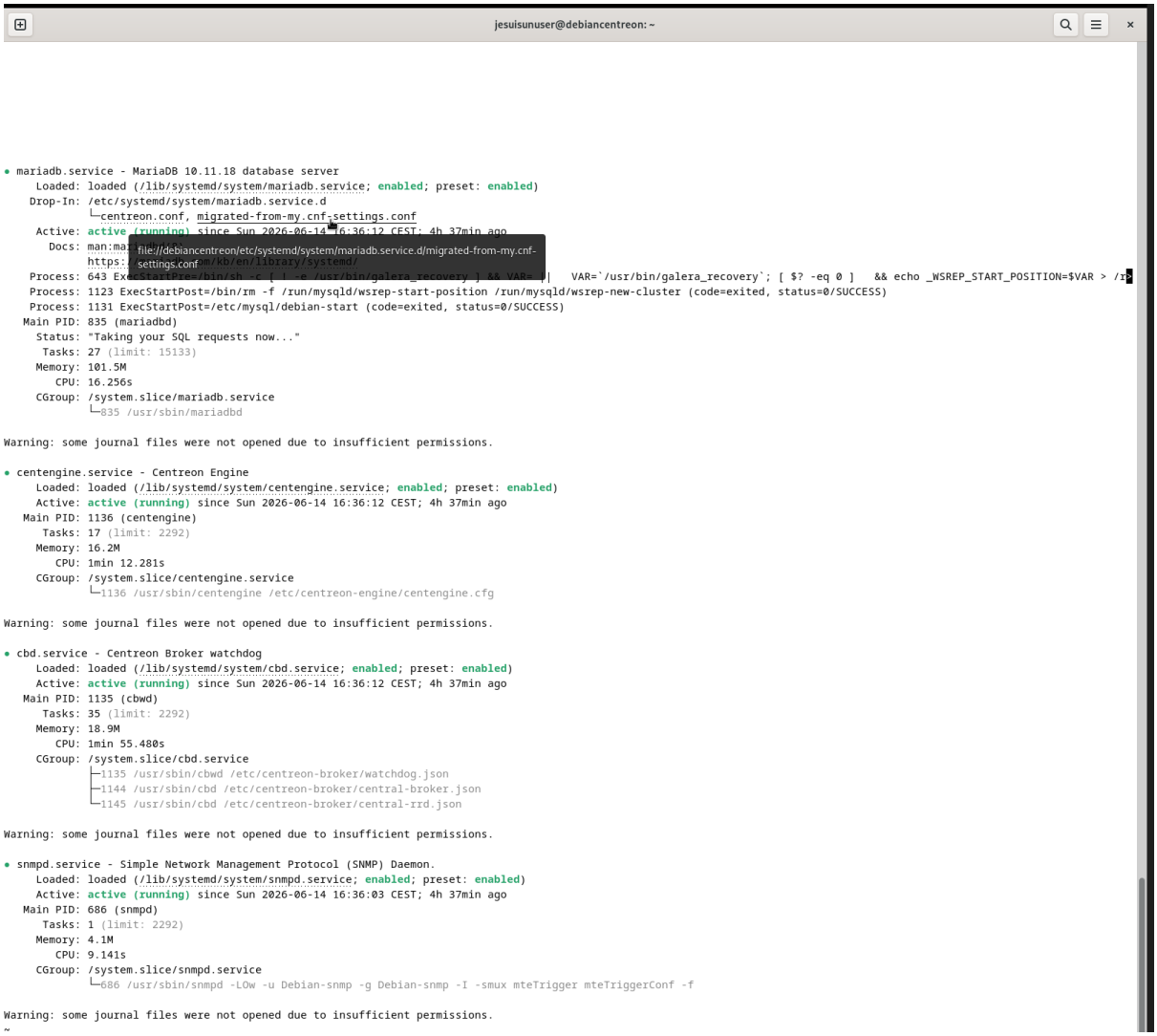


Figure 29 : État des services Centreon

Un assistant de configuration, accessible depuis un navigateur web, finalise ensuite l'installation : il connecte Centreon à la base de données, crée le compte administrateur, et démarre les derniers services nécessaires. À l'issue de cette étape, l'interface web de supervision est accessible et prête à recevoir des machines à surveiller.

.

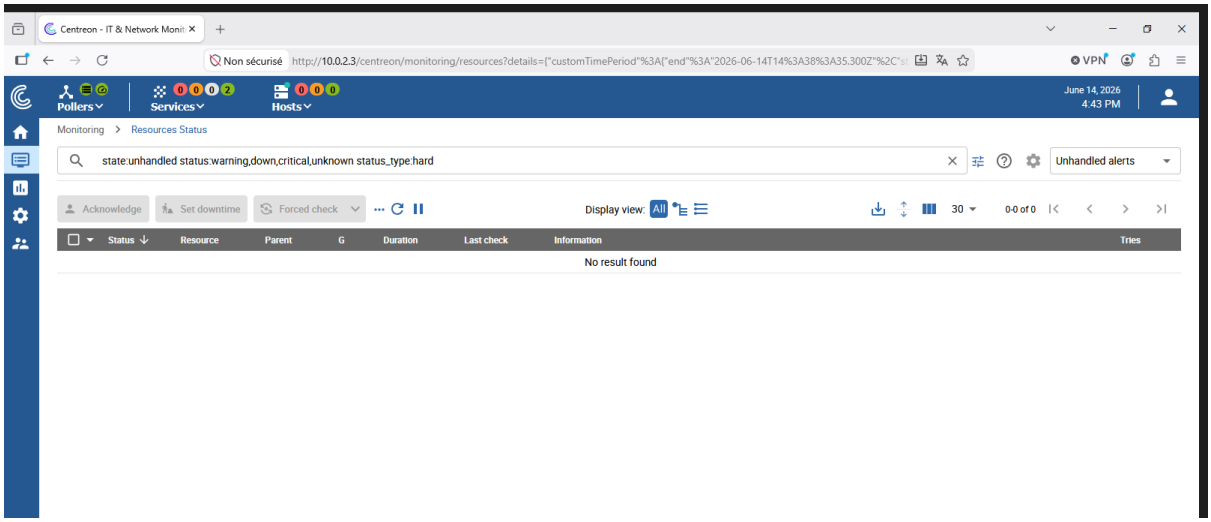


Figure 30 : Page d'accueil web Centreon après installation

iii. Préparation du contrôleur de domaine

Pour que Centreon puisse interroger le contrôleur de domaine, ce dernier doit pouvoir répondre. Il faut donc activer et configurer l'agent SNMP sur le serveur Windows.

```
PS C:\Users\Administrateur> Get-WindowsFeature -Name SNMP-Service, SNMP-WMI-Provider

Display Name                                            Name                    Install State
------------                                            ----                    -------------
[X] Service SNMP                                        SNMP-Service                Installed
    [ ] Fournisseur WMI SNMP                            SNMP-WMI-Provider           Available
```

Figure 31 : Installation de SNMP sur le Windows Server

Trois réglages sont nécessaires. D'abord installer le service SNMP, absent par défaut. Ensuite définir la communauté, le mot de passe partagé qui autorise l'interrogation, et la mettre en lecture seule : Centreon doit pouvoir lire les valeurs, jamais modifier quoi que ce soit sur la machine surveillée. Enfin restreindre les réponses à l'adresse du serveur Centreon, pour qu'aucune autre machine ne puisse interroger le contrôleur de domaine.

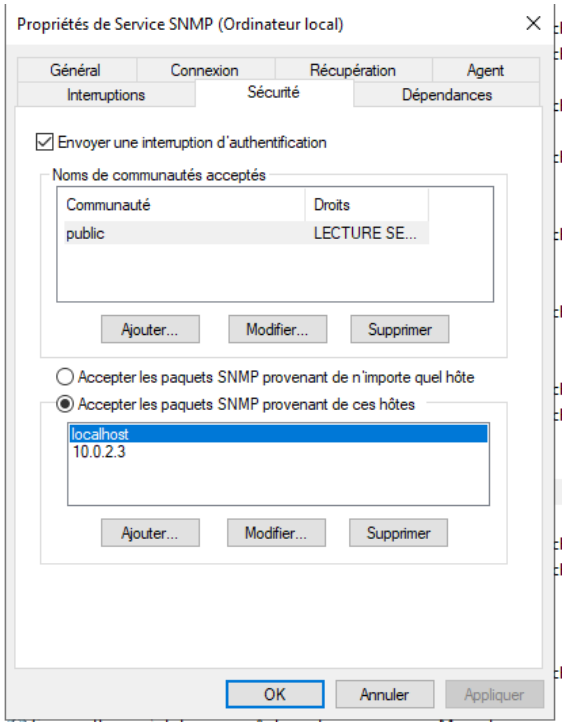


Figure 32 : Configuration du service SNMP

Ce dernier point, c'est un réflexe de sécurité dans la continuité du reste du projet : on n'ouvre l'accès qu'à ce qui en a besoin. Superviser une machine ne doit pas créer une nouvelle faille.

Une fois l'agent configuré, j'ai vérifié depuis Centreon que le contrôleur de domaine répondait bien à une requête SNMP. Cette étape est importante : elle confirme que la communication fonctionne avant d'aller plus loin.

```
root@debiancentreon:~# snmpget -v2c -c public 10.0.2.15 1.3.6.1.2.1.1.1.0
iso.3.6.1.2.1.1.1.0 = STRING: "Hardware: AMD64 Family 25 Model 117 Stepping 2 AT/AT COMPATIBLE - Software: Windows Version 6.3 (Build 17763 Multiprocessor Free)"
root@debiancentreon:~#
```

Figure 33 : Test de réponse SNMP depuis Centreon

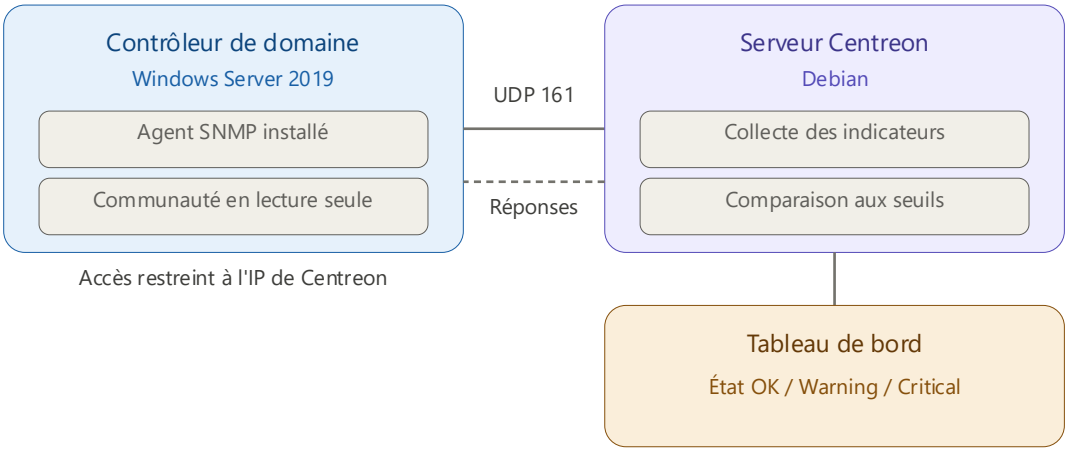


Figure 34 : Fonctionnement de Centreon pour interroger une machine

iv. Configuration des éléments supervisés

La dernière étape, c'est de déclarer dans Centreon ce qu'on veut surveiller.

Il existe des templates comportant un certain nombre de métrique à supervision que l'on a juste à ajouté a un hôte (mon contrôleur de domaine)

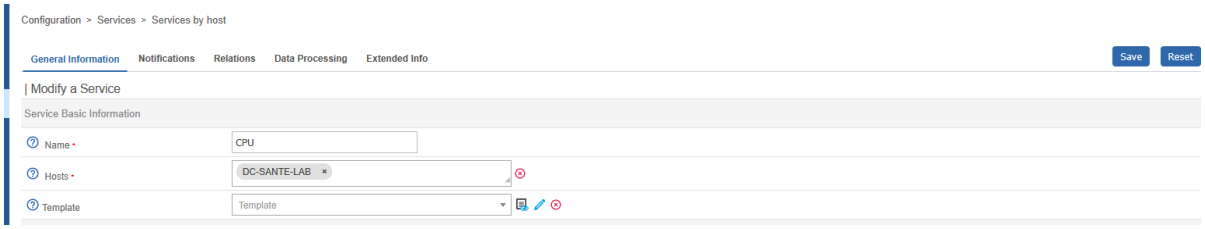


Figure 35 : Template grisé sur la version de Centreon utilisée

Ici je n'ai pas pu utiliser de templates, j'ai donc du configurer les commandes à la main.

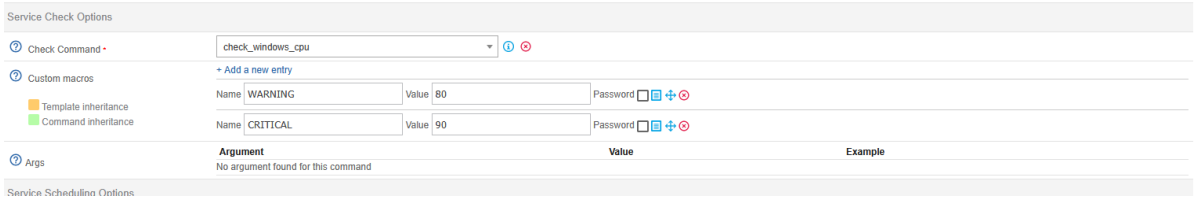


Figure 36 : Ajout de la commande de vérification du CPU

J'ai doncajouté le contrôleur de domaine comme hôte, avec son adresse et la communauté SNMP définie précédemment. Puis j'ai créé les indicateurs à surveiller. Pour le contrôleur de

domaine, j'en ai retenu trois : l'utilisation du processeur, l'utilisation de la mémoire, et l'espace disque disponible.

Ce sont les trois signaux qui annoncent la majorité des incidents en pratique : un processeur saturé ralentit le serveur, une mémoire pleine fait planter les services, un disque plein bloque l'écriture et peut arrêter l'annuaire.

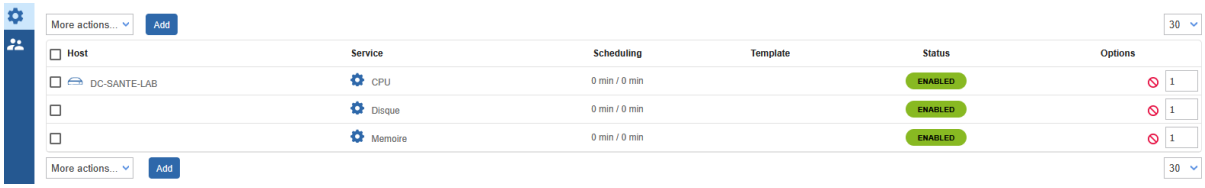
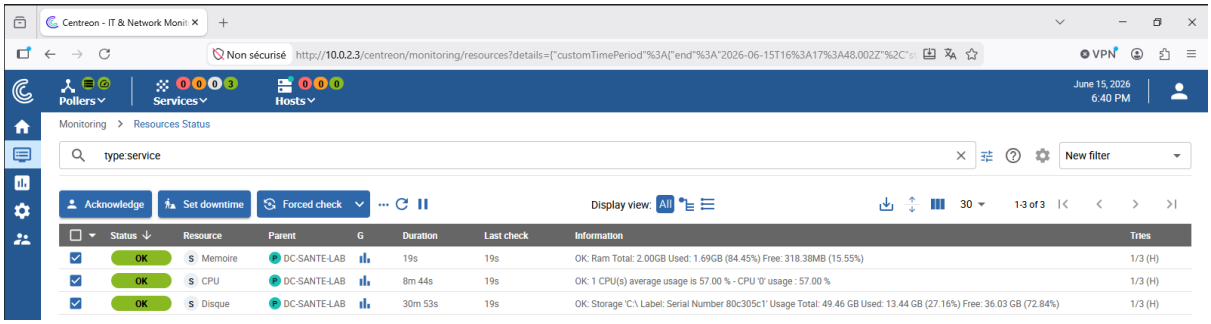


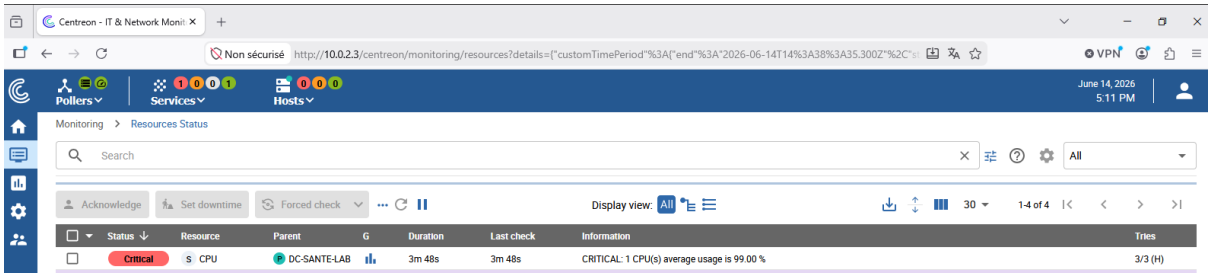
Figure 37 : Visualisation des trois indicateurs dans Centreon

Chaque indicateur correspond à une requête SNMP, avec deux seuils : un seuil d'avertissement et un seuil critique. Sous le seuil d'avertissement, l'indicateur est vert. Entre les deux seuils, il passe en orange — un signal d'attention. Au-delà du seuil critique, il passe en rouge — un incident à traiter.



v. Démonstration de la détection d'incident

Pour vérifier que la détection fonctionne réellement, et pas seulement en théorie, voici un exemple réel observé sur le lab : le contrôleur de domaine a atteint 99% d'usage CPU, et l'indicateur est immédiatement passé en état Critical dans l'interface de Centreon.



Cette démonstration confirme que la supervision réagit au franchissement d'un seuil et signale l'incident sans intervention humaine. Le seuil a ensuite été remis à sa valeur normale, et l'indicateur est repassé au vert. C'est précisément ce comportement qui distingue une gestion proactive d'une gestion réactive : le problème est rendu visible par l'outil, au moment où il apparaît, plutôt que découvert par l'utilisateur une fois le service interrompu.

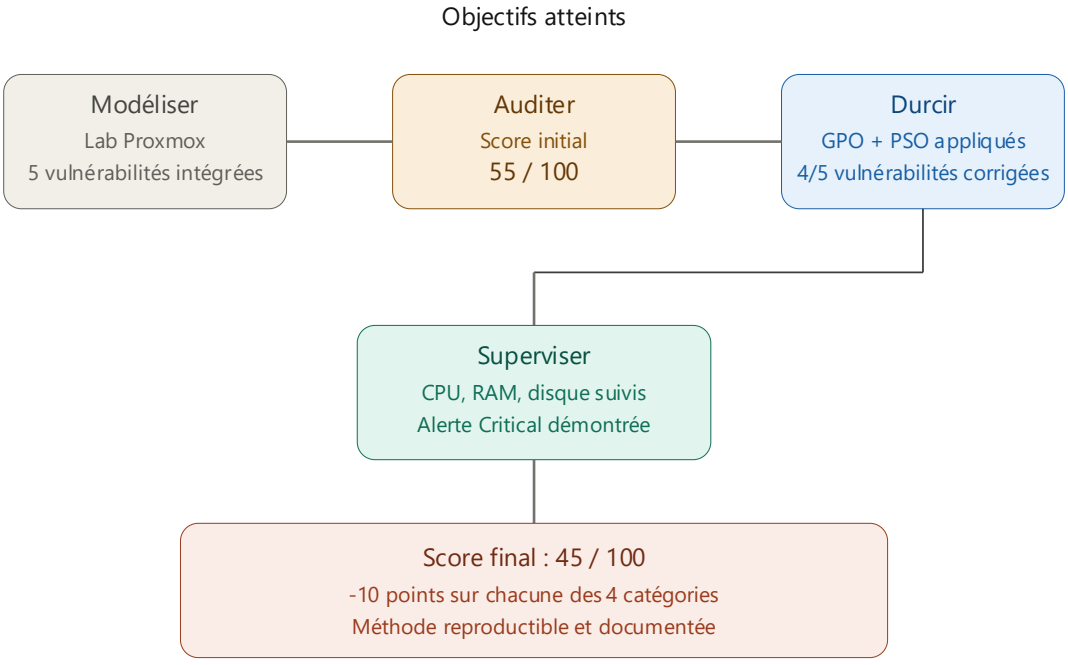
3. Bilan

a. Résultats obtenus

Au regard des objectifs fixés en début de mission, le projet a abouti à un environnement de simulation fonctionnel, reproduisant une infrastructure Active Directory type d'un établissement de santé. Les vulnérabilités introduites ont été détectées par l'audit initial PingCastle, qui a établi un Domain Risk Level de référence.

Après application des correctifs — GPO et PSO, conformes aux recommandations de l'ANSSI — un second audit dans les mêmes conditions a fait baisser le score dans chacune des quatre catégories. La supervision Centreon est opérationnelle : les indicateurs critiques du contrôleur de domaine (CPU, mémoire, disque) sont suivis en continu, et une alerte s'est déclenchée en conditions réelles pendant le projet.

Le score résiduel n'est pas un échec : aucun annuaire n'atteint zéro, et les points restants relèvent soit de la configuration par défaut de Windows Server, soit de bonnes pratiques avancées (rotation de la clé krbtgt, déploiement de LAPS) laissées hors périmètre. Les objectifs initiaux sont atteints : modéliser, auditer, durcir, puis superviser une infrastructure de référence, avec une méthode reproductible.



b. Difficultés rencontrées

La principale difficulté du projet est survenue en configurant la supervision du contrôleur de domaine dans Centreon.
Pour superviser une machine Windows, Centreon propose normalement un module tout prêt : on l'ajoute, et la configuration se fait presque seule. Le problème, c'est que ce module fait partie d'une offre payante, qui n'était pas disponible dans la version utilisée. Impossible donc de passer par cette solution simple.

En creusant, j'ai trouvé que le logiciel nécessaire était bien installé sur le serveur, seulement il fallait le configurer entièrement à la main, sans aide de l'interface. J'ai d'abord vérifié que ça fonctionnait en testant une commande directement sur le serveur — ça a marché, le serveur a bien remonté l'utilisation du processeur du contrôleur de domaine. Ensuite, j'ai recréé manuellement, étape par étape, ce que le module payant aurait fait automatiquement.
Cette difficulté m'a obligé à comprendre comment la supervision fonctionne vraiment, dans le détail, plutôt que de cliquer sur un bouton "tout configurer".

c. Perspectives

Le durcissement de l'annuaire Active Directory et la mise en place d'une supervision active constituent une première étape de sécurisation, mais ne couvrent pas l'ensemble des risques pesant sur la continuité de service, en particulier pour des structures comme les établissements de santé, où une interruption du système d'information a un impact direct sur l'activité.

Une suite logique à ce projet serait l'intégration d'un plan de reprise d'activité (PRA), s'appuyant sur une solution telle que Veeam Backup & Replication. L'objectif serait de garantir, en cas de panne du contrôleur de domaine ou d'un serveur critique, une bascule rapide vers un environnement de secours, répliqué en continu ou restauré à partir d'une sauvegarde récente, afin de limiter au minimum la durée d'indisponibilité (RTO) et la perte de données (RPO).

D'autres axes prolongeraient naturellement la démarche de durcissement : le déploiement d'une authentification multifacteur (MFA) sur les accès sensibles, l'adoption d'un modèle de hiérarchisation des privilèges (tiering) d'Active Directory, la gestion centralisée des mots de passe administrateurs locaux via LAPS, ou encore l'extension de la supervision à des indicateurs propres à l'annuaire (état des services AD DS, réplication entre contrôleurs).

Conclusion

En travaillant sur les clients de l'agence pendant mon alternance, j'ai remarqué que pas mal d'AD — surtout chez les clients du secteur de la santé — n'avaient jamais été vraiment audités ni durcis. Le problème, c'est qu'on ne peut pas tester ça sur l'AD d'un client réel, trop risqué. J'ai donc monté mon propre lab, isolé, pour pouvoir auditer et durcir un AD de bout en bout, sans contrainte.

J'ai modélisé un environnement sous Proxmox, reproduisant une infrastructure type d'un établissement de santé. J'y ai introduit plusieurs vulnérabilités courantes, pour avoir un point de départ réaliste. Un premier audit PingCastle a donné un score de référence.

J'ai ensuite durci l'infrastructure avec des GPO et des PSO, en m'appuyant sur les recommandations de l'ANSSI. Le second audit a fait baisser ce score. Pour finir, j'ai mis en place une supervision avec Centreon, pour détecter les problèmes avant qu'ils n'impactent le service.

Ce projet m'a permis de construire une vraie méthode, reproductible, que je pourrai réutiliser sur d'autres AD. La suite logique serait d'aller plus loin avec un plan de reprise d'activité, pour couvrir le risque de panne majeure.

Bilan humain

Cette alternance m'a permis de m'intégrer rapidement dans le monde professionnel. J'ai mené ce projet en autonomie, avec le soutien de mon tuteur et de l'équipe quand j'en avais besoin.
La bonne ambiance dans l'agence a beaucoup compté. Dès le début, j'ai pu poser mes questions sans difficulté, ce qui a facilité mon intégration.
La différence avec l'IUT, je l'ai surtout vue sur les contraintes : le matériel disponible, les licences qu'on n'a pas forcément, les délais, la responsabilité envers le client. À l'IUT, le cadre est plus carré. En entreprise, il faut s'adapter et faire des choix.
Cette expérience m'a confirmé que je veux continuer dans la cybersécurité. Sur le plan personnel, j'ai gagné en autonomie, en rigueur, et en confiance pour expliquer mon travail à d'autres.

Abstract

During my second-year apprenticeship at XEFI Advanced Auvergne, an IT service provider for small and medium businesses, I noticed that many of our healthcare clients run on Active Directory infrastructures that are critical for their daily operations, but are rarely audited or hardened in depth. Since testing security configurations on a real client's AD is too risky, I decided to build my own isolated lab to practice auditing and hardening an AD from start to finish.

I built an isolated lab environment under Proxmox VE, reproducing a typical infrastructure for a healthcare organisation: a domain controller running Windows Server 2019, client workstations, and a dedicated monitoring server. To have a realistic starting point, I deliberately introduced four common vulnerabilities found in small structures with limited resources: an outdated and unsafe file-sharing protocol (SMBv1), a name-resolution protocol vulnerable to credential capture (LLMNR), a weak password policy, and an inactive administrator account that had never been disabled.

To measure the security level of this environment objectively, I used PingCastle, a free and open-source Active Directory auditing tool whose rules are based on the recommendations of ANSSI, the French national cybersecurity agency. The initial audit set a reference Domain Risk Level. I then hardened the infrastructure using Group Policy Objects and a fine-grained password policy, following ANSSI's guidelines on passwords and entropy. A second audit, run under the same conditions, lowered the score — a measurable improvement on every category evaluated.

Finally, I deployed Centreon, an open-source monitoring platform, to supervise the domain controller over SNMP. I configured monitoring for CPU usage, memory, and disk space, with warning and critical thresholds. During the project, a real CPU spike triggered a critical alert, which confirmed that the monitoring system reacts correctly to abnormal events — moving from a reactive approach (waiting for a user to report an issue) to a proactive one (detecting problems before they affect the service).

Beyond the technical skills, this project was also a real experience of integration into professional life. I worked mostly independently, with support from my supervisor and the team whenever I needed it. I saw clearly how working in a company differs from working at university: real constraints such as available hardware, software licensing limits, deadlines, and responsibility towards clients force you to make choices and adapt, where the academic environment is more structured and theoretical. This project confirmed my interest in cybersecurity, and gave me a reusable method that I can apply to other Active Directory environments in the future.

Glossaire

Active Directory (AD) : service d'annuaire de Microsoft centralisant la gestion des comptes, des ordinateurs et des règles de sécurité d'un domaine Windows.

ANSSI : Agence nationale de la sécurité des systèmes d'information, autorité française de référence en cybersécurité.

Centreon : plateforme open source de supervision des systèmes, serveurs et équipements réseau.

Contrôleur de domaine : serveur qui héberge l'annuaire Active Directory, authentifie les connexions et applique les politiques de sécurité du domaine.

DMZ : zone démilitarisée ; segment réseau isolé hébergeant des services exposés, sans donner accès au réseau interne.

Entropie : mesure de l'imprévisibilité d'un mot de passe, exprimée en bits ; plus elle est élevée, plus le mot de passe est difficile à deviner.

GPO (Group Policy Object) : stratégie de groupe permettant d'appliquer de façon centralisée des règles de configuration aux machines et utilisateurs d'un domaine.

Hyperviseur : logiciel permettant d'exécuter plusieurs machines virtuelles sur un même serveur physique.

ICMP : protocole réseau utilisé notamment pour tester la disponibilité d'un équipement (ping).

Kerberoasting : attaque consistant à demander un ticket de service Kerberos afin d'en extraire hors ligne le mot de passe du compte de service associé.

Kerberos : protocole d'authentification d'Active Directory reposant sur des tickets chiffrés.

LAPS : solution de gestion centralisée et de rotation automatique des mots de passe administrateurs locaux.

LLMNR : protocole de résolution de noms local, détournable par un attaquant pour capturer des empreintes d'authentification.

Moindre privilège : principe consistant à n'accorder à un compte que les droits strictement nécessaires à sa fonction.

PingCastle : outil d'audit de sécurité d'Active Directory générant un score de risque et un rapport détaillé.

PRA (Plan de reprise d'activité) : ensemble de procédures visant à rétablir le système d'information après un sinistre majeur.

Proxmox VE : hyperviseur open source utilisé pour virtualiser l'environnement de simulation.

PSO (Password Settings Object) : politique de mot de passe affinée appliquée à un groupe précis d'un domaine.

RTO / RPO : durée maximale d'indisponibilité admissible (RTO) et perte de données maximale admissible (RPO).

SMB / SMBv1 : protocole de partage de fichiers et d'imprimantes sous Windows ; sa version 1 (SMBv1) est obsolète et vulnérable.

SNMP : protocole standard de supervision des équipements réseau et serveurs, fonctionnant sur un modèle question-réponse.

vSwitch : commutateur réseau virtuel gérant les communications entre machines virtuelles d'un hyperviseur.

Bibliographie

ANSSI, Recommandations relatives à l'authentification multifacteur et aux mots de passe, version 2.0, octobre 2021. ssi.gouv.fr
ANSSI, Recommandations de sécurité relatives à Active Directory. ssi.gouv.fr
ANSSI, Recommandations relatives à l'administration sécurisée des systèmes d'information reposant sur Microsoft Active Directory, octobre 2023. cyber.gouv.fr
Microsoft Learn, Active Directory Domain Services, Documentation. learn.microsoft.com
Microsoft Learn, Server Message Block (SMB) protocol, Documentation. learn.microsoft.com
Microsoft Learn, LAPS (Local Administrator Password Solution), Documentation. learn.microsoft.com
PingCastle, Documentation officielle. pingcastle.com
Centreon, Documentation officielle. docs.centreon.com
Proxmox, Proxmox VE, Documentation. pve.proxmox.com

Annexes

Annexes — Commandes et procédures

Cette annexe regroupe les commandes utilisées au cours du projet, organisées par section du rapport. Les emplacements de captures d'écran à insérer sont indiqués en italique.

1. Vérification du domaine

Commande utilisée pour confirmer l'opérationnalité du domaine sante-lab.local après promotion du contrôleur de domaine :

```
Get-ADDomain
```

2. Détection et correction des comptes

Détection des comptes inactifs encore activés

```
Search-ADAccount -UsersOnly -AccountInactive -TimeSpan 90.00:00:00 |
   Where-Object { $_.Enabled -eq $true }
```

Vérification d'un compte spécifique

```
Get-ADUser -Identity "ancien.admin" -Properties Enabled, LastLogonDate
```

Désactivation / réactivation d'un compte

```
Disable-ADAccount -Identity "ancien.admin"
Enable-ADAccount -Identity "ancien.admin"
```

Vérification des membres d'un groupe à privilèges (récursif)

```
Get-ADGroupMember -Identity "Admins du domaine" -Recursive |
   Select-Object Name, SamAccountName, ObjectClass
```

3. Durcissement par stratégies de groupe (GPO)

Les correctifs suivants ont été appliqués via la console de gestion des stratégies de groupe (GPMC), et non en ligne de commande :

- Désactivation de SMBv1 (capacité client et serveur)
- Activation de la signature SMB
- Désactivation de LLMNR
- Politique de mot de passe par défaut du domaine (longueur, complexité, expiration)
- Politique de mot de passe affinée (PSO) pour le groupe des comptes sensibles

[Insérer ici les captures GPMC correspondantes]

4. Vérification des correctifs

```
Get-SmbServerConfiguration |
   Select-Object EnableSMB1Protocol, EnableSMB2Protocol, EnableSecuritySignature

Get-ADDefaultDomainPasswordPolicy

Get-ADFineGrainedPasswordPolicy -Filter *
```

5. Installation de Centreon (Debian 12)

Ajout du dépôt MariaDB

```
curl -LsS https://r.mariadb.com/downloads/mariadb_repo_setup | bash -s -- \
   --os-type=debian --os-version=12 --mariadb-server-version="mariadb-10.11"
```

Ajout des dépôts Centreon

```
echo "deb https://packages.centreon.com/apt-standard-24.10-stable/ $(lsb_release -sc)
main" | \
   tee /etc/apt/sources.list.d/centreon.list

echo "deb https://packages.centreon.com/apt-plugins-stable/ $(lsb_release -sc) main" | \
   tee /etc/apt/sources.list.d/centreon-plugins.list
```

Clé GPG du dépôt

```
wget -O- https://apt-key.centreon.com | gpg --dearmor | \
   tee /etc/apt/trusted.gpg.d/centreon.gpg > /dev/null 2>&1
```

Installation des paquets

```
apt update && apt install -y centreon-mariadb centreon
```

Activation et démarrage des services

```
systemctl enable mariadb centreon cbd centengine gorgoned snmpd
systemctl start mariadb centreon cbd centengine gorgoned snmpd
```

5bis. Commandes de supervision créées dans Centreon

Le connecteur Windows étant indisponible (licence Business), les commandes suivantes ont été créées manuellement dans l'interface Centreon (Configuration > Commandes), en s'appuyant sur le plugin centreon_windows_snmp.pl déjà installé.

Test préalable en ligne de commande (sur le serveur Centreon)

```
/usr/lib/centreon/plugins/centreon_windows_snmp.pl \
   --plugin=os::windows::snmp::plugin --mode=cpu \
   --hostname=10.0.2.15 --snmp-version=2c --snmp-community=public
```

Commande check_windows_cpu

```
$CENTREONPLUGINS$/centreon_windows_snmp.pl --plugin=os::windows::snmp::plugin
--mode=cpu --hostname=$HOSTADDRESS$ --snmp-version='$_HOSTSNMPVERSION$'
--snmp-community='$_HOSTSNMPCOMMUNITY$' --warning-
average='$_SERVICEWARNING$'
--critical-average='$_SERVICECRITICAL$'
```

Commande check_windows_memory

```
$CENTREONPLUGINS$/centreon_windows_snmp.pl --plugin=os::windows::snmp::plugin
--mode=memory --hostname=$HOSTADDRESS$ --snmp-
version='$_HOSTSNMPVERSION$'
--snmp-community='$_HOSTSNMPCOMMUNITY$' --warning-
usage='$_SERVICEWARNING$'
--critical-usage='$_SERVICECRITICAL$'
```

Commande check_windows_storage

```
$CENTREONPLUGINS$/centreon_windows_snmp.pl --plugin=os::windows::snmp::plugin
```

--mode=storage --hostname=$HOSTADDRESS$ --snmp-version='$_HOSTSNMPVERSION$'
--snmp-community='$_HOSTSNMPCOMMUNITY$' --warning-usage='$_SERVICEWARNING$'
--critical-usage='$_SERVICECRITICAL$'

Pour chaque commande, un service correspondant a été créé sur l'hôte DC-SANTE-LAB, avec des seuils Warning/Critical à 80/90.

6. Configuration SNMP côté contrôleur de domaine

Vérification de l'installation de la fonctionnalité SNMP :
Get-WindowsFeature -Name SNMP-Service, SNMP-WMI-Provider

7. Test de connectivité SNMP depuis Centreon

snmpget -v2c -c public 10.0.2.15 1.3.6.1.2.1.1.1.0

4eme de couverture : Sécurisation d'une infrastructure client santé

Jules TEYSSIER, BUT Réseaux & Télécommunications, parcours Cybersécurité

Ce rapport présente un projet de sécurisation d'une infrastructure Active Directory représentative d'un établissement de santé, mené chez XEFI Ingénierie Auvergne. À partir d'un laboratoire virtualisé, des vulnérabilités courantes ont été introduites, auditées avec PingCastle, puis corrigées selon les recommandations de l'ANSSI, avant la mise en place d'une supervision proactive sous Centreon. La démarche, reproductible et fondée sur des référentiels reconnus, réduit de façon mesurable le niveau de risque de l'annuaire et renforce la continuité de service.

Version publique : les résultats chiffrés de l'audit PingCastle, l'organigramme de l'agence et les noms des personnes ont été retirés. Le laboratoire ne contient aucune donnée de client réel.

Mots-clés : **Active Directory · Durcissement · ANSSI · GPO · PSO · Audit de sécurité · PingCastle · Supervision · Centreon · SNMP · Cybersécurité · Santé · PRA**